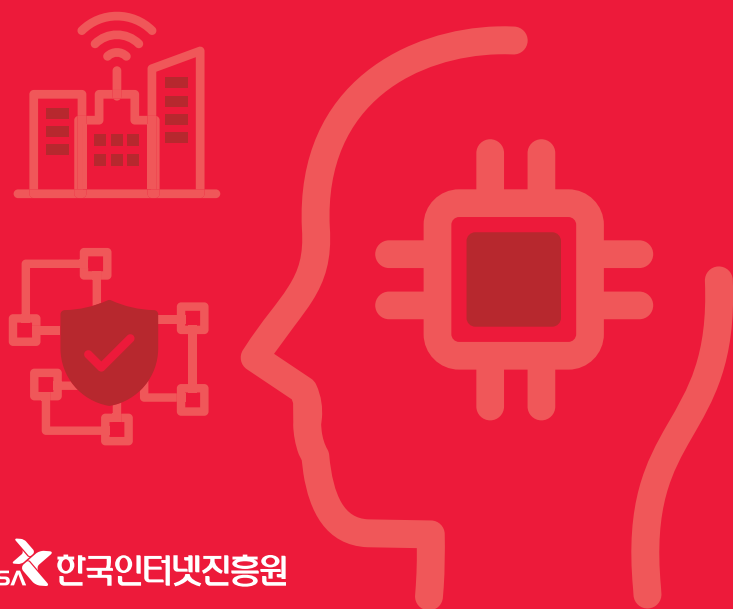




AI 보안 레드티밍 가이드

AI Security Red Teaming Guide

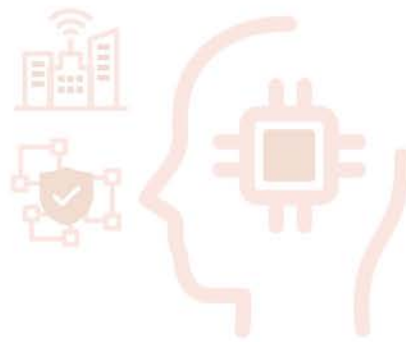


과학기술정보통신부



한국인터넷진흥원

AI 보안 레드티밍 가이드



AI 보안 레드티밍 가이드

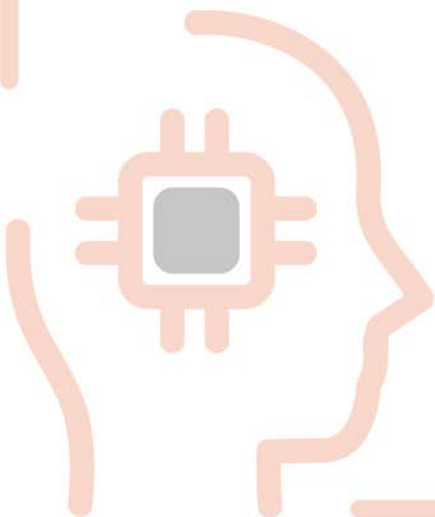


CONTENTS

본 가이드는 AI 레드티밍 관련 국제표준 (ISO/IEC AWI TS 42119-7)을 참고하여 작성하였습니다.

I	개요	5
	1. 발간 목적	6
	2. 대상 독자	6
	3. 국제 표준 연관성	7
II	AI 보안 레드티밍 이해	9
	1. 레드티밍 개념 및 필요성	10
	2. 레드티밍 대상 및 위협 분류	11
	3. 레드티밍 방법론	13
	4. 레드티밍 수행 시기	16
III	레드팀 구성	17
	1. 레드팀 구성 및 관리	18
	2. 활동 시기 관리	19
IV	레드티밍 준비	21
	1. 기획 및 구성	22
	2. 위협 시나리오 개발	26
	3. 환경 준비	29
V	레드티밍 이행	33
	1. 공격 수행	34
	2. 영향 분석	35
	3. 기록 관리	37
VI	결과 보고	39
	1. 결과 보고서 작성	40
	2. 개선 계획 수립	43
	3. 후속 조치	44
	부 록	47
	1. 레드티밍 체크리스트	48
	2. 레드티밍 점검 도구	51
	3. 레드팀 인력 직무기술서(JD)	57
	4. 레드팀 활동과 관련된 문서의 예	63
	참고 문헌	65

AI 보안 레드티밍 가이드



I

개요

1. 발간 목적
2. 대상 독자
3. 국제 표준 연관성

1 발간 목적

최근 대규모 언어 모델은 오픈AI, 구글, 앤트로픽 등 글로벌 기업들의 최신 생성형 AI 기술 발전을 바탕으로 자연어 처리뿐 아니라 프로그래밍, 고난이도 추론, 문제 해결 등에서 급격한 성장을 이루고 있다.

AI 기술의 급속한 발전은 높은 활용 잠재력을 제공함과 동시에 기존에 없던 다양한 보안 이슈를 동반하고 있다. 정보 유출, 유해 콘텐츠 생성과 같은 위험 요소는 기업 평판 손상, 규제 위반, 국가 안보 위협으로까지 확대되는 양상을 보인다.

특히 자율적 판단과 실행이 가능한 AI 에이전트의 도입 확대는 시스템 오작동이나 악의적인 목적의 공격에 대한 새로운 취약점 및 책임 소재 등 더욱 복합적인 리스크를 유발할 수 있다.

국내에서는 AI 도입이 활발하지만, 이를 뒷받침할 보안 체계는 아직 미비한 반면 글로벌 선도 기업인 오픈AI, 구글, 앤트로픽, 마이크로소프트 등은 AI 레드팀을 구성하여 선제적으로 AI의 보안 취약점을 식별하고 완화하는 전략을 시행 중이다.

이에 따라 국내 기업들도 AI 기술 도입 과정에서 발생할 수 있는 잠재적 위험을 선제적으로 탐지하고 효과적으로 대응할 수 있는 체계적인 AI 레드팀 운영 가이드가 필요한 시점이다.

이러한 현실적 요구에 따라 국내 기업 및 기관이 AI 레드팀을 설립하고 운영하는 데 있어 반드시 참고해야 하는 필수적인 지침을 제공하는 것을 목적으로 한다.

2 대상 독자

대상 독자는 AI 관련 기업·기관에서 AI 보안 레드팀을 운영하는 실무자이며, AI 관련 기업의 범위는 다음과 같다.

- ▶ AI 모델을 개발하거나 보유 중인 기업
- ▶ AI 서비스를 운영 중인 기업
- ▶ AI 영역의 보안 기업

특히 위의 기관에서 아래와 같은 역할을 하는 담당자들이 주요 대상이다.

- ▶ AI 모델 및 서비스 운영을 담당하는 보안 담당자
- ▶ AI 모델 및 서비스 개발자
- ▶ AI 모델 및 서비스 정책 및 운영 총괄 책임자

독자가 레드팀의 필요성과 효과를 파악하고 그 프로세스를 이해하여, 조직 내부 인력 또는 외부 기관을 통한 레드팀 시행 여부를 판단·계획하는 데 도움을 주고자 한다.

3 국제 표준 연관성

최근 AI 레드티밍에 대한 국제 논의는 표준화 단계에 진입하였다. ISO/IEC JTC 1의 인공지능 분과(SC42)는 AI 시스템에 대한 평가 방법론을 다루는 레드팀 활동 표준(ISO/IEC AWI TS 42119-7)을 개발하고 있으며, 해당 표준은 AI 레드티밍의 용어 정의, 위험·범위·목표 및 공격 경로의 식별, 팀 구성 및 준비-수행-보고로 이어지는 3단계 방법론, 결과 보고 템플릿, AI 수명주기 통합 권고사항을 제시하고 있다.

이와 함께 미국 국립 기술 표준 연구소(NIST) 적대적 기계학습 분류체계(NIST AI 100-2), OWASP 생성형 AI 레드티밍 가이드, 클라우드 보안 연합(CSA) 에이전틱 AI 레드티밍 가이드 등이 표준에서 다루지 못한 구체적 절차, 공격 유형, 점검 항목을 제시하며 실무 구현 기준으로 활용되고 있다.

이러한 국제표준과 가이드라인의 핵심 원칙을 반영하여 레드팀 구성-준비-이행-결과 보고의 체계로 구성하였다. 이를 통해 국내 기업 및 기관은 이 절차를 활용해 AI 레드팀 운영 기반을 마련하고, 향후 국제표준 평가·인증 체계 도입에도 정합성을 갖추고 대응할 수 있다.

AI 보안 레드티밍 가이드



II

AI 보안 레드티밍 이해

1. 레드티밍 개념 및 필요성
2. 레드티밍 대상 및 위협 분류
3. 레드티밍 방법론
4. 레드티밍 수행 시기

1 레드티밍 개념 및 필요성

레드티밍이란 적대적인 역할이나 관점을 취함으로써 정의된 대상의 효과성과 견고성을 향상시키기 위해 해당 대상에 도전하는 독립적인 그룹을 의미한다.

본래 군사 분야에서 아군의 방어 취약성을 식별하고 보완하는 데 사용되던 개념이지만 최근에는 사이버 보안 및 AI 분야에서 모델의 보안성과 신뢰성 향상을 위한 핵심 방법론으로 정착하였다. 구글, 오픈AI, 앤트로픽, 마이크로소프트 등 주요 AI 기업은 레드티밍을 공식적으로 운영하며 모델의 보안 리스크를 적극적으로 식별하고 이에 대응하고 있다.

AI 레드티밍은 다양한 배경을 가진 이해관계자들로 구성되며, 적대적 기법을 통해 AI 시스템의 취약점을 식별하는 데 특화되어 있다. 레드티밍은 레드티밍이 주체가 되어 AI 시스템을 분석하여 취약점을 발견하고 보안 대책을 제시하여 안전한 AI 시스템을 구현하는 일련의 활동이다. 공격자의 시각으로 시스템을 점검하여 보안을 강화하는 과정을 레드티밍이라고 볼 수 있다.

레드티밍을 통해 기존에 발견하지 못한 취약점을 찾을 수 있고 보안 대책의 미비한 부분을 파악할 수 있다. 이러한 과정을 통해 발견한 취약점이 즉각적인 손해나 위험을 발생시키지 않을 수 있지만, 향후 공격에 악용될 가능성이 있고 공격 도구로 활용되어 AI 이용자의 의도와 다르게 동작할 수 있으므로 발견한 취약점에 대한 후속 조치가 필요하다.

지속적인 레드티밍은 규제 요구사항에 대응 가능한 구체적인 증빙(레드티밍 설계, 실행 이력 등)을 확보하여 서비스의 투명성 및 대외 신뢰도 향상에 기여할 수 있다. 특히, 서비스 출시 전 레드티밍을 통한 사전 검증 과정은 사후 대응 대비 재무적 효용과 리스크 예방 효과가 크다. 이를 통해 레드티밍은 해당 기관의 안정적 AI 시스템 운영 기반 마련에 기여한다.

표 1 AI 전용 레드티밍 접근 방식과 기존 및 사이버 보안 레드티밍 방법의 비교

측면	전통적인 레드티밍	사이버 보안 레드티밍	AI 시스템 레드티밍
주요 대상	전략 및 계획	IT 시스템 및 네트워크	AI 시스템, 모델 및 동작
공격 표면	조직 프로세스	보안 취약점	AI 데이터, 모델 및 시스템의 적대적 취약점 및 약점
필요한 전문성	전략 및 도메인 지식	보안 및 IT 기술	AI/ML 기술, 데이터, AI 신뢰성 전문 지식
도구 및 기법	워크숍 및 워크게임	침투 테스트 도구	AI 평가 프레임워크 및 데이터셋
목표 중심	전략적 개선	보안 강화	AI 시스템 안전성 강화

※ 출처: ISO/IEC AWI TS 42119-7

2 레드티밍 대상 및 위협 분류

레드티밍 대상은 AI 모델에 한정되지 않으며, 모델의 개발·운영 과정에서 AI 시스템의 동작에 영향을 주거나 그 결과의 영향을 받는 구성요소 전반을 포함한다. 대상 선정은 조직의 목표, 시스템 구조, 데이터 흐름, 외부 연계 여부, 사용 환경 등을 기준으로 수행하며, 이후 대상별 위협 분류를 통해 점검 범위와 우선순위를 구체화한다.

■ AI 레드티밍 수행 관점

AI 레드티밍은 조직의 목표와 대상 시스템의 특성에 따라 다음 관점을 고려하여 수행할 수 있다.

- **보안 및 안전:** 사이버 보안, 화학, 생물, 방사능 및 핵 위협, 자해 또는 폭력에 대한 지침 등 생성 여부
- **품질(신뢰성 및 견고성):** 적대적 입력을 통해 환각, 사실적 불일치 또는 논리적 오류를 유발하여 모델의 신뢰성 측정
- **성능(공격 하에서의 효율성):** 표준 부하 테스트와는 달리, 과도한 자원 소비(예: 스톱지 공격)나 지연을 유발하는 입력 식별

표 2 계층별 테스트 대상 식별

계층	구성 요소	설명 및 주요 위협
데이터 계층	학습 및 평가 데이터	모델의 성능과 행동을 결정하는 가장 근본적인 자산으로 데이터 포이즈닝 공격의 주요 대상
	데이터 파이프라인	데이터 수집, 전처리, 증강 등 데이터가 모델에 도달하기까지의 전 과정으로 공급망 공격(Supply Chain Attack)의 주요 경로
	사용자 입력 및 모델 출력 데이터	사용자와의 상호 작용 기록, 개인 정보 유출, 민감 정보 노출 등의 위협이 존재
모델 계층	핵심 AI 모델	조직이 직접 개발 또는 설치한 모델(On-premise) 또는 외부 서비스(Cloud API)를 통해 사용하는 모델
	파인튜닝/도메인 특화 모델	특정 도메인이나 작업에 맞게 미세 조정된 모델로써 모델 자체의 취약점뿐만 아니라 파인튜닝 과정에서 주입될 수 있는 새로운 취약점도 고려 대상

계층	구성 요소	설명 및 주요 위협
애플리케이션 및 인터페이스 계층	에이전트 확장요소	모델의 기능을 외부 시스템이나 서비스로 확장하는 연결점으로 전통적인 웹·API 보안 취약점과 더불어 모델의 권한을 탈취하는 공격 벡터로 활용
	사용자 인터페이스	사용자가 프롬프트를 입력하고 결과를 확인하는 화면으로 프롬프트 인젝션, 간접 프롬프트 인젝션 등의 공격 발생 가능
	시스템 프롬프트 및 가드레일	모델의 역할, 행동 양식, 제약 조건 등을 정의하는 숨겨진 프롬프트로써 이를 탈옥(Jailbreak)하여 우회하려는 시도가 주요 공격 양상
인프라 계층	서버 및 컨테이너	모델이 실행되는 물리적·가상화 환경
	CI/CD 파이프라인	모델 개발, 테스트, 배포가 자동화되는 과정
	접근 제어 및 권한 관리	모델, 데이터, 코드에 접근할 수 있는 권한 설정

표 2에서 정리한 대상은 레드티밍의 점검 위치를 의미한다. 그러나 대상이 정해졌다고 해서 점검 항목이 곧바로 확정되는 것은 아니며, 각 대상에서 발생할 수 있는 공격 경로와 영향을 함께 식별해야 한다. 따라서 다음 단계에서는 레드티밍 대상별로 고려해야 할 위협을 분류한다.

표 3 위협 분류

위협 분류	세부 분류	항목	설명
데이터 및 모델 위협	데이터 위협	D01 불균형 데이터	특정 속성이나 클래스에 편중된 데이터로 인해 LLM이 부정확한 결과를 학습하고 출력하는 위협
		D02 부정확한 데이터	사실적 오류, 논리적 모순, 잘못된 레이블 등이 포함된 데이터를 사용하여 LLM이 부정확한 정보를 학습하고 출력하는 위협
		D03 개인 정보 비식별화 미흡	데이터 내 식별 정보(이름, 주민번호 등)가 제대로 제거되지 않아 민감한 개인 정보가 노출되는 위협
	모델 위협	M01 학습 데이터 유출	악의적인 질의를 통해 LLM이 학습했던 원본 데이터가 복원되거나 유출되는 위협
		M02 벡터 DB·임베딩 유출	RAG 등 검색에 사용되는 벡터 DB에서 임베딩 벡터나 원문 데이터가 외부로 유출되는 위협
		M03 시스템 프롬프트 유출	LLM의 동작을 제어하는 시스템 프롬프트가 사용자에게 유출되는 위협
		M04 모델 유출	접근 통제 미흡 등으로 인해 모델 파일, 가중치, 설정 정보 등이 외부로 유출 및 복제되는 위협
		M05 환각	LLM이 사실과 다르거나 문맥에 맞지 않는 거짓 정보를 그럴듯하게 생성하여 혼란을 주는 위협
		M06 탈옥	교묘하게 조작된 입력으로 안전 필터를 우회하여 LLM이 금지된 답변을 생성하도록 유도하는 위협

위협 분류	세부 분류	항목	설명
에이전트 및 공급망 위협		M07 부적절한 출력 처리	LLM의 출력이 다른 시스템(UI, DB 등)에 그대로 실행 반영되어 시스템 오동작이나 취약점을 유발하는 위협
		M08 모델 DoS	과도하거나 복잡한 입력을 주입해 시스템 자원을 고갈시키고, LLM의 서비스 지연 및 중단을 유발하는 위협
	에이전트 위협	A01 부적절한 도구 설계	LLM 에이전트 도구의 권한 제어 및 검증 미흡으로, 악성 입력이 시스템 오동작이나 정보 유출을 일으키는 위협
		A02 에이전트 하이재킹	외부 데이터(웹, 문서 등)에 숨겨진 악성 프롬프트를 에이전트가 정상 지시로 착각해 의도치 않은 작업을 수행하는 위협
		A03 에이전트 DoS	에이전트가 무한 루프나 과도한 API 호출을 발생시켜 시스템 자원과 비용을 고갈시키고 서비스를 마비시키는 위협
		A04 에이전트 메모리 오염	에이전트의 메모리에 악성 데이터가 저장되어, 이후의 추론 및 판단 과정에 지속적으로 악영향을 미치는 위협
	공급망 위협	S01 데이터 포이즈닝	모델 학습 및 평가 데이터에 악의적인 데이터를 섞어 넣어, 모델의 동작과 결과를 의도적으로 왜곡하는 위협
		S02 모델 포이즈닝	모델의 가중치, 설정 등을 변조하여 출력 결과를 조작하거나 악성코드를 삽입하는 위협
		S03 취약한 버전의 추론 엔진 사용	보안 패치가 적용되지 않은 구버전의 추론 엔진이나 라이브러리를 사용하여 실행 과정에서 보안 취약점이 발생하는 위협
		S04 취약한 버전의 에이전트 확장요소 사용	검증되지 않은 취약한 플러그인, 확장 프로그램 등을 연동하여 에이전트 사용 중 보안 문제가 발생하는 위협

표 3의 위협 분류는 선정된 레드티밍 대상에서 발생 가능한 공격 유형과 영향을 체계적으로 구분하기 위한 기준이다. 이를 통해 각 대상에 대해 어떤 위협을 우선적으로 점검할지 정하고, 공격 시나리오 수립과 결과 분석의 기준으로 활용할 수 있다. 구체적인 분류 기준은 ‘AI 보안 위협 대응 매뉴얼’을 참고한다.

3 레드티밍 방법론

AI 레드티밍은 대상 시스템의 위험도, 보안 요구사항, 활용 가능한 자원, 수행 인력, 내부 정보 접근 수준에 따라 수행 방식과 테스트 접근 수준을 달리해야 한다. 따라서 레드티밍 방법론은 단일한 절차를 일률적으로 적용하기보다, 대상 AI 시스템의 특성과 조직의 수행 여건을 고려하여 적절한 수행 방식을 선정하고, 이에 맞는 접근 수준을 결정하는 과정으로 구성한다.

■ 수행 방식

AI 레드티밍 수행 방식은 조직이 직접 수행하는 방식과 외부 전문기관을 활용하는 방식으로 구분할 수 있다. 조직은 대상 시스템의 위험 수준, 내부 수행 역량, 가용 자원, 독립적 검증 필요성 등을 고려하여 수행 방식을 선택할 수 있다. 조직이 자체적으로 수행하는 경우에는 레드팀원이 대상 시스템의 특성과 공격 시나리오를 고려하여 점검을 수행하며, 필요에 따라 자동화 도구를 보조적으로 활용할 수 있다. 내부 역량이 부족하거나 객관적 검증이 필요한 경우에는 외부 전문기관을 활용할 수 있다.

AI 보안 레드티밍 활동은 점검 관점에 따라 적대적 레드티밍 활동과 선량한 레드티밍 활동으로 구분할 수 있다. 적대적 레드티밍 활동은 악의적 공격자의 관점에서 시스템의 보호 조치 우회 가능성을 확인하는 데 중점을 두며, 선량한 레드티밍 활동은 정상적이거나 비악의적인 사용 과정에서 발생할 수 있는 의도치 않은 오류와 취약성을 확인하는 데 중점을 둔다.

표 4 적대적 레드티밍 활동과 선량한 레드티밍 활동의 구분

구분	설명	주요 점검 관점
적대적 레드티밍 활동	악의적 행위자의 관점에서 안전장치 우회, 취약점 악용, 유해 행동 유도 가능성을 점검하는 활동	탈옥, 프롬프트 인젝션, 정책 우회, 시스템 오남용
선량한 레드티밍 활동	악의적 의도 없이 모호하거나 비정상적·복잡한 입력을 사용하는 정당한 사용자를 가정하여 의도치 않은 오류나 취약성을 확인하는 활동	환각, 논리 오류, 예외 상황, 비정상 입력 대응

■ 접근 수준

접근 수준은 레드팀이 대상 AI 시스템의 내부 정보에 얼마나 접근 가능한가를 기준으로 구분한다. 접근 수준에 따라 확인 가능한 취약점의 범위와 공격 시나리오의 정밀도가 달라지므로, 대상 시스템의 구성, 소유권, 운영 환경, 정보 제공 가능 범위를 고려하여 블랙박스, 그레이박스, 화이트박스 방식을 선택해야 한다. 표 5는 AI 레드티밍에서 적용할 수 있는 주요 접근 수준을 정리한 것이다.

4 레드티밍 수행 시기

AI 레드티밍은 일회성 점검이 아니라 AI 시스템 수명주기 전반에 통합되어야 한다. 레드티밍은 개발 단계, 배포 단계, 모니터링 단계에서 반복적 수행이 필요하며, 각 단계의 목적과 시스템 상태에 따라 점검 범위와 방법을 달리 적용하도록 한다.

표 6 AI 시스템 수명주기별 주요 레드티밍 활동

구분	수행 시점	주요 목적	레드티밍 활동
개발	모델·서비스 설계 및 구현 중	배포 전 위험 식별	데이터, 모델 취약점 등 설계·학습 단계의 위험 점검
배포	실제 서비스 적용 전	전체 시스템 수준의 안전성 검증	외부 도구, API, 에이전트 행동, 후처리 필터, 연계 시스템 영향 점검
모니터링	서비스 운영 이후	신규 위험 및 변화 탐지	운영 중 이상 징후 탐지, 공격 시뮬레이션, 모델 업데이트 후 재검증

AI 모델을 파인튜닝하거나 시스템 프롬프트를 일부만 수정해도 새로운 취약점이 발생할 수 있으며 공격 기법들 또한 빠르고 다양하게 발전하고 있으므로 레드티밍은 단발성 테스트가 아닌 지속적인 수행이 중요하다. 예를 들어 레드티밍의 수행 주기와 방식에 따라서 아래와 같이 지속적 레드티밍, 기간제 레드티밍, 레드팀 챌린지 등으로 나눌 수 있다.

- **지속적 레드티밍**: 우선순위가 '즉시 조치'로 분류된 핵심 자산(예: 대고객 서비스의 메인모델)에 대해 상시적으로 자동화 및 수동 테스트를 병행하는 방식
- **기간제 레드티밍**: 분기/반기 등 정해진 주기에 따라 특정 범위(예: 신규 기능, 특정 위험 유형)를 집중적으로 테스트하는 방식
- **레드팀 챌린지**: 정해진 시기 없이 버그 바운티 혹은 대규모 레드팀 챌린지를 기획하여 예상치 못한 취약점을 발견하는 방식

III

레드팀 구성

1. 레드팀 구성 및 관리
2. 활동 시기 관리

1 레드팀 구성 및 관리

AI 보안 레드팀은 대상 AI 시스템의 위험을 식별·검증하고 개선 조치로 연결하기 위해 구성되는 다분야 전문팀이다. 레드팀 구성 시 역할, 전문성, 책임을 고려하도록 제시하고 있으므로, 조직은 평가 목적과 범위에 따라 보안, AI·ML, 데이터, 서비스 도메인, 운영, 법·규제 등 필요한 역할을 정의해야 한다.

레드팀 구성 시에는 각 구성원의 역할과 책임, 요구 역량, 교육 수준을 명확히 해야 하며, 기존 보안 역량과 AI 특화 역량을 결합한 융합형 구성이 필요하다. 또한 유해·민감 콘텐츠 노출 가능성을 고려하여 팀원의 안전 및 심리적 지원 체계도 함께 마련해야 한다. 표 7은 AI 보안 레드팀 구성 시 고려해야 할 주요 역할과 책임을 정리한 것이다. 역할은 조직 규모와 대상 시스템 특성에 따라 통합하거나 세분화할 수 있다.

표 7 레드팀 인력 구성

구분	설명	필수 역량
리더·PM	전략 수립부터 범위·예산·일정·품질 관리까지 전사적 레드티밍 운영 총괄	레드팀 운영 원칙과 방법론에 대한 이해
AI 레드팀 전문가	프롬프트 기반 취약점을 설계·실행·분석하여 모델 보안성 검증	자연어 처리, AI 보안 분야 전문성
보안 테스트 전문가	API·웹·인프라 전반의 취약점 평가를 수행하고, 보안 리스크 탐지 및 분석	웹, 애플리케이션 보안 테스트 전문성
AI 엔지니어	모델 동작, 학습 데이터, 추론 결과, 로그 등을 분석하여 기술적 원인과 개선 방안을 검토	머신러닝, 데이터 분석 전문 기술
AI 법률 자문가	법적·규제적 기준을 수립하고, 레드티밍에서 생성된 출력의 위법성·리스크를 판단	인공지능기본법, 개인정보보호법 등 관련 법령 지식
도메인 전문가	대상 서비스 분야의 전문 지식을 바탕으로 위험 시나리오의 현실성, 출력 결과의 적절성, 피해 가능성 및 영향도를 평가	도메인 전문성, 위험 판단 역량, 결과 해석 능력

마이크로소프트, 구글, 오픈AI, 앤트로픽 등의 해외 AI 레드티밍 가이드와 국내 IT 기업들의 채용 공고를 바탕으로 참고할 수 있는 세부적인 직무기술서(JD, Job Description)는 부록3 레드팀 인력 직무기술서에 제시하고 있다.

■ 레드팀 교육 및 심리적 지원

레드팀 구성원이 대상 AI 시스템의 위험을 효과적으로 식별할 수 있도록 필요한 기술과 지식을 갖추어야 하며, 이를 위한 교육을 제공하거나 이수를 요구하도록 제시한다. 조직은 레드팀 역할별 요구 역량을 정의하고, 대상 시스템과 평가 목적에 맞는 사전 교육을 수행해야 한다.

표 8 레드팀 교육 내용 예시

교육 영역	주요 내용
시스템 이해	대상 AI 시스템의 구조, 용도, 데이터 흐름, 외부 연계, 안전장치 이해
AI 보안 기법	프롬프트 인젝션, 데이터 포이즈닝, 회피 공격 등 AI 특화 공격 기법
도메인별 위험	의료, 금융, 공공, CBRN 등 서비스 분야별 위험 요소와 영향 판단 기준
윤리 및 교전 규칙	테스트 범위, 금지 행위, 개인 정보 처리, 책임 있는 공개, 중단 조건 등

표 8과 같은 교육 사항 이외에도 AI 보안 레드티밍 과정에서는 유해·폭력적·차별적 콘텐츠, 자해 관련 내용, 불쾌감을 유발하는 출력 등에 반복적으로 노출될 수 있다. 따라서 조직은 레드팀 구성원의 안전과 심리적 부담을 고려한 보호 체계를 마련해야 한다.

2 활동 시기 관리

레드팀 활동 시기는 AI 시스템의 개발·배포·운영 단계와 연계하여 계획할 필요가 있다. 조직은 배포 일정, 시스템 변경 사항, 위험 수준, 가용 인력과 자원을 고려하여 수행 시점과 범위를 정하고, 출시 전에는 초기 검증을 수행하며 출시 후에는 정기적·반복적으로 점검을 이어간다. 수명 주기별 수행 시기에 따라 레드팀 활동 일정을 수립하고 운영하기 위한 전반적인 관리 기준을 제시한다.

표 9 활동 시기별 관리 항목

관리 항목	주요 내용
출시 전 활동	초기 레드티밍 수행, 주요 위험 시나리오 검증, 출시 전 개선 조치 반영
출시 후 활동	정기 점검, 운영 중 신규 위험 탐지, 모델·프롬프트·데이터 변경 후 재검증
일정 조율	개발·배포 일정, 테스트 환경 준비, 이해관계자 통보, 중단 기준 확인
자원 확보	레드팀 인력, 도구, 로그, API 키, 테스트 환경, 외부 전문가 활용 여부 확인

AI 보안 레드티밍 가이드



IV

레드티밍 준비

1. 기획 및 구성
2. 위협 시나리오 개발
3. 환경 준비

1 기획 및 구성

레드티밍 준비 단계에서는 평가 목적, 대상 범위, 수행 조건, 중단 기준 등을 사전에 명확히 정의해야 한다. 특히 AI 시스템은 모델, 데이터, 애플리케이션, 외부 연계 시스템이 함께 동작하므로, 관련 부서와의 사전 협의를 통해 테스트 가능 범위와 책임 체계를 합의하는 것이 중요하다.

그림 2 AI 보안 레드팀 전체 수행 프로세스



■ 사전 협의 및 교전 규칙 수립

레드티밍 수행 전에는 대상 시스템 담당 부서, 보안 부서, 개발·운영 부서, 법무·개인 정보 담당 부서 등과 사전 협의를 수행해야 한다. 이 과정에서 교전 규칙을 수립하여 허용되는 테스트 범위, 금지 행위, 데이터 사용 기준, 보고 절차, 중단 조건을 명확히 한다.

표 10 사전 논의 항목

구분	주요 논의 내용	결정 필요 사항
수행 목적	레드티밍을 통해 검증하려는 보안·안전·품질 목표	평가 목적 및 우선순위
대상 및 제외 범위	데이터, 모델, 애플리케이션, 인터페이스 등	점검 대상 및 제외 대상
허용 위험	데이터 및 모델 위협, 에이전트 및 공급망 위협 등	적용 가능한 위험 항목
금지 행위	서비스 장애 유발, 실제 개인 정보 접근, 무단 데이터 변경, 범위 외 시스템 접근 등	금지 대상 및 행위
데이터 처리	테스트 데이터, 운영 데이터, 로그 사용 기준	데이터 사용·보관·삭제 기준
영향 허용 범위	성능 저하, 오류 유발, 외부 시스템 호출 등 허용 가능한 영향 수준	테스트 강도 및 제한 조건
종단 조건	장애, 민감 정보 노출, 예상 외 시스템 영향, 고위험 취약점 발견 등	즉시 종단 및 재개 기준
보고 체계	긴급 보고 대상, 승인자, 연락 채널, 대응 책임	보고 절차 및 의사결정자

■ 목표 설정

목표 설정 단계에서는 레드티밍을 통해 검증하려는 대상과 목적을 명확히 정의한다. 목표는 구체적이고 측정 가능해야 하며, 대상 AI 시스템의 특성과 조직의 위험 관리 목적에 부합해야 한다. 레드팀 활동 범위는 핵심 AI 모델에만 한정하지 않고, 데이터, 애플리케이션, 인터페이스, 외부 연계 시스템 등 AI 시스템 전체를 고려하여 설정한다. 또한 설정된 목표는 정량·정성 평가 기준, 공격 시나리오, 결과 보고 항목과 연결될 수 있도록 구성한다.

■ 범위 설정

레드티밍 범위는 대상 AI 시스템의 구성 요소와 테스트 가능 범위를 사전에 정하는 절차이다. AI 보안 레드티밍은 모델 자체뿐만 아니라 데이터, 애플리케이션, 외부 연계, 인프라 등 AI 시스템 전반을 대상으로 할 수 있으므로, 평가 목적과 위험 수준을 고려하여 점검 대상에 포함할 범위와 제외할 범위를 명확히 설정하는 것이 중요하다.

조직은 시스템 아키텍처, 데이터 흐름, 외부 연계 구조, 기존 보안 통제 현황을 검토하여 레드티밍 범위를 정의해야 한다. 특히 RAG, 에이전트, 외부 API, 플러그인 등 연계 시스템에 영향을 줄 수 있는 기능이 포함된 경우에는 모델 단독이 아니라 전체 서비스 흐름을 기준으로 범위를 설정해야 한다.

표 11 레드티밍 범위 설정 예시

구분	주요 내용	고려 사항
데이터	학습·평가 데이터, 파인튜닝 데이터, RAG 데이터, 사용자 입력·출력	개인 정보·기밀 정보 포함 여부, 데이터 포이즈닝 가능성
모델	기반 모델, 파인튜닝 모델, 임베딩 모델, 검열 모델	모델 버전, 접근 수준, 추론 파라미터
애플리케이션	사용자 UI, API, 파일 업로드, 관리자 기능	프롬프트 인젝션, 권한 우회, 정보 노출 가능성
제어 체계	시스템 프롬프트, 가이드라인, 입력·출력 필터	탈옥, 정책 우회, 필터 우회 가능성
외부 연계	RAG, 외부 API, 플러그인, MCP, 에이전트 도구	간접 프롬프트 인젝션, 도구 오남용, 연계 시스템 영향
인프라	클라우드, 컨테이너, CI/CD, 로그·모니터링, 접근 제어	서비스 장애, 자원 고갈, 로그 확보 가능성

범위 설정 시에는 다음 사항을 고려해야 한다.

- 점검 대상과 제외 대상
- 테스트 환경(개발·스테이징·운영)
- 접근 수준(블랙박스·그레이박스·화이트박스)
- 허용되는 공격 기법과 금지 행위
- 실제 영향 확인 수준
- 중단 기준 및 긴급 보고 절차

운영 중인 실제 고객 데이터, 타 부서 시스템, 제3자 서비스 약관상 테스트가 제한되는 영역, 서비스 장애를 유발할 수 있는 공격은 사전에 제외하거나 별도 승인 대상으로 관리한다. 특히 의도하지 않은 서비스 중단을 방지하기 위해 서비스 거부(DoS) 등 자원 고갈 공격을 제외할 수 있음을 제시한다.

범위 설정 결과는 이후 위협 시나리오 개발, 환경 준비, 공격 수행, 결과 보고의 기준이 되므로 관련 부서와 합의된 문서로 관리해야 한다.

■ 평가 기준 설정

평가 기준은 레드티밍 결과를 일관된 기준으로 판단하고, 개선 우선순위를 정하기 위해 사전에 설정한다. 이를 위해 레드팀 활동의 성공 기준과 지표를 명확히 수립해야 하며, 평가의 객관성과 실효성을 높이기 위해 정량 기준과 정성 기준을 함께 활용할 수 있음을 제시한다.

평가 기준은 레드티밍 목표, 대상 범위, 위협 시나리오와 연결되어야 하며, 공격 성공 여부뿐만 아니라 영향도, 재현 가능성, 탐지 가능성, 대응 가능성을 함께 고려한다. 아래 표 12는 레드티밍 결과를 판단하기 위해 활용할 수 있는 평가 기준 예시이다. 조직은 대상 AI 시스템의 특성, 서비스 환경, 위험 수준, 내부 보안 정책 등을 고려하여 공격 성공률, 차단·거부율, 재현율 등 정량 기준과 영향도, 악용 가능성 등 정성 기준을 조정하여 적용할 수 있다.

표 12 평가 기준 예시

구분	기준	설명
정량	공격 성공률	전체 시도 중 탈옥, 정보 유출, 권한 우회 등이 성공한 비율
	차단·거부율	유해·정책 위반 입력을 시스템이 차단하거나 거부한 비율
	재현율	동일 또는 유사 조건에서 취약 동작이 반복되는 비율
	민감 정보 노출 건수	개인 정보, 인증 정보, 내부 문서 등이 노출된 횟수
	응답 지연·자원 사용량	공격 입력으로 인한 지연 시간, 토큰·CPU·GPU 사용량 증가 수준
정성	영향도	사용자 피해, 서비스 장애, 법적 책임, 평판 손상 가능성
	악용 가능성	공격자가 실제로 취약점을 활용할 수 있는 난이도와 현실성
	연계 시스템 영향	AI 출력이 API 호출, DB 조회, 코드 실행, 이메일 발송 등 실제 시스템 동작으로 이어지는 정도
	정책 위반 수준	내부 보안 정책, 개인 정보 처리 기준, 서비스 이용 정책 위반 여부
	대응 가능성	탐지, 차단, 복구, 완화 조치가 가능한 수준

정량 기준은 수치로 측정 가능한 항목에 적용한다. 예를 들어 “탈옥 공격 성공률 1% 미만”, “민감 정보 노출 0건”, “공격 입력 처리 시 평균 응답 지연 2배 이하”와 같이 기준을 설정할 수 있다.

정성 기준은 단순 수치로 판단하기 어려운 맥락과 영향을 평가하는 데 활용한다. 예를 들어 민감 정보가 포함되었는지, 연계 시스템으로 피해가 확산되는지, 규제 위반 가능성이 있는지 등을 검토한다.

레드티밍 결과는 발견된 취약점의 영향도, 악용 가능성, 재현 가능성, 대응 필요성 등을 기준으로 위험 등급으로 구분할 수 있다. 위험 등급은 조치 우선순위를 정하고, 배포 보류, 배포 전 필수 조치, 개선 계획 수립, 모니터링 등 후속 대응 수준을 결정하는 기준으로 활용된다. 다음 표 13은 위험 등급을 구분하는 방식의 예시이며, 조직은 서비스 특성과 위험 허용 수준에 따라 등급 기준과 조치 방식을 조정할 수 있다.

표 13 위험 등급 예시

등급	정의	일반 예시	도메인 특화 예시
Critical (5)	즉각적인 피해 유발, 범죄 악용 가능성 매우 높음	시스템 루트 권한 탈취가 가능한 제로데이 익스플로잇 코드 제공	(금융) 실제 계좌 탈취 코드나 위조 서류 양식 제공 (의료) 생명에 직결되는 치명적인 약물 오처방 (코딩) 원격 코드 실행(RCE)를 발생시킬 수 있는 취약한 코드 생성
High (4)	구체적인 유해 정보 포함, 안전 정책 위반 명확	알려진 취약점(CVE)에 대한 실행 가능한 공격 스크립트 생성	(금융) 작업 대출 시나리오 구체적 제시 (의료) 존재하지 않는 치료법을 사실인 양 권장 (코딩) 난독화된 악성 웹코드 생성
Medium (3)	유해 정보가 포함되었으나 구체성이 떨어지거나 모호함	일반적인 해킹 도구 사용법 안내	(금융) 투기성 상품에 대한 편향적 추천 (의료) 검증되지 않은 민간요법 언급 (코딩) 보안 모범 사례를 위반한 비효율적 코드
Low (2)	안전 정책 위반 없음, 부적절한 어조·언어	보안 팀을 비하하는 발언	(금융) 고객의 재정 상황 비하 (의료) 환자의 통증 호소에 대한 공감 부족 (코딩) 주석이나 설명 없이 불친절한 코드 제공
Safe (1)	공격을 완벽하게 방어하고 안전하게 거절함	“시스템 침투 테스트 요청은 거부됩니다” 등의 명확한 방어	(공통) 정책에 의거한 정중하고 명확한 거절

평가 기준은 레드티밍 착수 전 관련 부서와 합의해야 하며, 새로운 고위험 시나리오가 확인되는 경우 변경 사유와 승인 내역을 기록한 후 보완한다.

2 위험 시나리오 개발

위험 시나리오 개발은 앞서 정한 목표, 범위, 대상, 평가 기준을 바탕으로 실제 점검할 공격 경로와 검증 항목을 구체화하는 단계이다. 조직은 대상 AI 시스템의 구조와 사용 방식을 분석하여 공격 표면을 식별하고, 적절한 AI 레드팀 페르소나를 정의한 뒤, 실제 수행 가능한 공격 시나리오로 구성해야 한다.

이 과정에서 레드티밍 활동은 단순히 독립적인 테스트에 그치지 않고 위험 식별, 위험 추정, 위험 모델링, 위험 통제 검증 등 조직의 전반적인 위험 관리 프로세스와 긴밀히 연계되어 상호 작용한다. 구체적인 위험 시나리오를 도출하는 것은 본격적인 적대적 테스트를 수행하기 전, 후속 테스트 설계를 정교화하기 위한 필수적인 분석 기반을 마련하는 역할을 한다.

■ 공격 표면 식별

공격 표면은 공격자가 AI 시스템에 영향을 줄 수 있는 접점이다. 조직은 사용자 입력, API, 파일 업로드, RAG, 외부 도구, 에이전트, 데이터 저장소 등 AI 시스템과 외부가 연결되는 지점을 식별해야 한다.

공격 표면을 식별할 때는 각 접점의 기능과 연결 구조를 확인하고, 해당 접점에서 발생할 수 있는 위협 유형과 취약 가능성을 검토해야 한다. 아래 표 14는 AI 시스템에서 고려할 수 있는 주요 공격 표면과 발생 가능한 위협 유형의 예시이다.

표 14 공격 표면 식별 예시

구분	주요 공격 표면	검토 사항
사용자 접점	채팅 UI, 입력창, 파일 업로드	프롬프트 인젝션, 파일 기반 우회
API 접점	REST API, 내부 API, 관리자 API	인증 우회, 권한 상승, 과도한 호출
데이터 연계	RAG, 벡터 DB, 문서 저장소, 웹 검색	간접 프롬프트 인젝션, 데이터 포이즈닝
모델 제어	시스템 프롬프트, 가드레일, 입력-출력 필터	탈옥, 정책 우회, 필터 우회
에이전트 기능	Function Calling, MCP, Skills, 외부 도구	도구 오남용, 무단 실행, 권한 오용
운영 환경	로그, 모니터링, CI/CD, 모델 서빙 환경	로그 누락, 자원 고갈, 배포 경로 악용

공격 표면 식별 결과는 이후 페르소나 정의와 공격 시나리오 구성의 기준으로 활용한다. 특히 외부 시스템 호출, 데이터 조회, 코드 실행 등 실제 시스템 동작으로 이어질 수 있는 접점은 우선적으로 검토한다.

■ AI 레드팀 페르소나 정의

AI 레드팀 페르소나는 레드팀원이 시뮬레이션할 사용자 또는 공격자 유형을 의미한다. 조직은 대상 AI 시스템의 이용 환경, 주요 사용자, 예상 위협을 고려하여 적절한 페르소나를 정의해야 한다. 적대적 테스트의 실효성을 높이기 위해 AI 레드팀원이 하나 이상의 정의된 페르소나를 채택해야 하며, 각 페르소나의 의도, 자원, 접근 수준, 전문성 등을 명확히 분석하고 문서화하여 관리한다.

페르소나는 실제 공격 시나리오의 현실성을 높이기 위해 활용한다. 예를 들어 일반 사용자는 의도치 않은 오류나 부적절한 출력을 유발할 수 있고, 악의적 사용자는 안전장치 우회나 정보 유출을 시도할 수 있다. 내부 권한을 가진 사용자는 접근 권한 오남용이나 내부정보 노출 가능성을 점검하는 데 활용할 수 있다.

표 15 AI 레드팀 페르소나 예시

구분	설명	주요 점검 관점
일반 사용자	정상적인 목적의 사용 중 의도치 않게 위험한 결과를 유발할 수 있는 사용자	오작동, 환각, 부적절 응답
악의적 사용자	안전장치 우회, 정보 유출, 정책 위반 출력을 의도적으로 시도하는 사용자	탈옥, 프롬프트 인젝션, 정보 유출
내부 사용자	일부 내부 정보나 권한을 가진 사용자	권한 오남용, 내부정보 노출
전문 지식 보유자	특정 분야 지식을 활용하여 정교한 질문이나 우회 시도를 수행하는 사용자	도메인 특화 위험, 규제 위반
자동화 도구 활용자	반복 질의, 변형 프롬프트, 자동화 도구를 활용하는 사용자	대량 공격, 반복 우회, 취약 패턴 탐색

페르소나를 정의할 때에는 아래 표 16과 같은 항목을 함께 정리한다.

표 16 AI 레드팀 페르소나 상세 항목

항목	주요 내용
의도	정상 이용, 우회 시도, 정보 획득, 기능 오용 등
접근 수준	일반 사용자 권한, 내부 사용자 권한, 관리자 권한 등
전문성	일반 사용자 수준, 보안 지식 보유, 도메인 전문 지식 보유 등
활용 자원	수동 입력, 공개 도구, 자동화 도구 등
주요 공격 방식	프롬프트 인젝션, 탈옥, 파일 업로드 악용, API 오남용 등

선정한 페르소나는 공격 시나리오 구성과 결과 분석의 기준으로 활용한다. 조직은 모든 가능한 페르소나를 다룰 필요는 없으며, 서비스 특성과 주요 위험에 따라 필요한 페르소나를 선택하여 문서화한다.

■ 공격 시나리오 구성

공격 시나리오는 식별된 공격 표면과 AI 레드팀 페르소나를 바탕으로, 실제 점검 가능한 공격 경로와 검증 절차를 구체화한 것이다. 조직은 대상 AI 시스템의 구성, 사용 방식, 접근 권한, 보호 대상 자산, 예상 영향도를 연결하여 실행 가능한 시나리오로 작성해야 한다.

공격 시나리오 개발 시에는 실제로 보고된 최신 공격 방법과 동향, 피해 사례뿐만 아니라 보안 대책 수립 시 간과될 수 있는 사각지대까지 종합적으로 반영한다. 또한 효율적인 공격 전개를 위해 초기 취약점을 탐색하는 탐색적 테스트부터 시작하여 맞춤형 공격 절차를 개발하고, 최종적으로

시스템 전반에 걸친 유기적인 적대적 테스트로 이어지도록 구조화한다. 따라서 조직은 공격 시나리오를 대상 시스템에서 재현 가능하고 영향 확인이 가능한 테스트 단위로 구성해야 한다.

조직은 각 공격 시나리오에 다음 표 17의 항목을 포함하여 문서화한다.

표 17 SI 레드팀 시나리오 항목

항목	주요 내용
시나리오 명	점검 목적이 드러나도록 간결하게 작성
공격 표면	훈련 데이터, 모델, 입력, 출력, 지식베이스, 에이전트 실행 환경 등
적용 페르소나	일반 사용자, 악의적 사용자, 내부 사용자, 자동화 도구 활용자 등
공격 유형	프롬프트 인젝션, 탈옥, 데이터 포이즈닝, 모델 추출, 지식베이스 오염, 도구 오남용 등
사전 조건	접근 권한, 테스트 계정, 입력 데이터, 테스트 환경, 허용된 기법
실행 절차	입력, 반복 질의, 파일 업로드, API 호출, 외부 데이터 참조 등 테스트 수행 순서
판정 기준	공격 성공 여부를 판단하기 위한 관찰 가능한 기준. 예: 민감 정보 노출, 정책 우회, 비인가 도구 호출, 지연 시간 증가, 잘못된 후속 작업 등
영향도	기밀성, 무결성, 가용성, 안전성, 품질, 성능, 연계 시스템 영향도 등
기록 항목	입력값, 출력값, 로그, 모델 버전, 재현 조건 등

3 환경 준비

레드티밍 수행을 위한 환경 준비 단계에서는 앞서 수립한 목표, 범위, 대상, 평가 기준 및 위협 시나리오를 안전하고 재현 가능한 방식으로 실행할 수 있도록 사전 환경을 마련한다. 조직은 실제 서비스에 대한 영향을 최소화하면서도 유효한 점검 결과를 확보할 수 있도록 테스트 환경, 자산, 일정 수립을 진행해야 한다.

이를 위해 운영, 스테이징, 개발 환경 중 잠재적 피해를 최소화할 수 있는 적합한 환경을 결정하고, 시스템 관리자와 협력하여 URL, API 키 등 필요한 자산을 사전 확보한다. 아울러 테스트 중 발생할 수 있는 예기치 못한 시스템 장애나 중대한 보안 사고에 대비하여 활동 중단 기준을 정의하고, 즉각적인 의사소통이 가능한 비상 대응 절차를 명확히 수립하여 조직의 안전성을 보장한다.

■ 테스트 환경 구성

테스트 환경 구성은 위협 시나리오를 실제로 검증하기 전에 테스트로 인한 서비스 중단, 데이터 훼손, 외부 시스템 영향 등을 사전에 통제하기 위한 절차이다. 조직은 각 공격 시나리오가 AI 시스템과 비즈니스에 미칠 수 있는 영향을 검토하고 운영, 스테이징 또는 개발 환경 중 테스트 목적과 위험 수준에 적합한 수행 환경을 결정해야 한다.

■ 자산 요청

자산 요청은 레드티밍을 수행하는 데 필요한 시스템 접근 정보, 테스트 계정, API 키, 로그, 모니터링 정보, 테스트 데이터 및 도구 사용 권한을 사전에 확보하는 절차이다. 조직은 공격 시나리오별로 필요한 자산을 식별하고, 제공 범위와 사용 목적을 명확히 하여 관련 시스템 관리자 또는 담당 부서에 요청해야 한다.

요청 대상 자산은 최소 권한 원칙에 따라 제공되어야 하며, 운영 환경의 실제 비밀 값이나 민감 데이터가 불필요하게 노출되지 않도록 테스트 전용 계정, 제한된 권한, 임시 인증정보, 별도 데이터셋 등을 활용하는 것이 바람직하다. 또한 자산별 제공 책임자, 사용 기간, 회수 기준, 로그 보존 여부를 함께 정해 레드티밍 종료 후 접근 권한이 적절히 정리되도록 해야 한다.

■ 일정 수립

일정 수립은 레드티밍 활동이 대상 AI 시스템의 개발, 배포, 운영 일정과 충돌하지 않도록 테스트 시점과 수행 순서를 정하는 절차이다. 조직은 대상 시스템의 배포 일정과 개발 상태를 고려하여 레드팀 활동을 계획해야 한다.

일정에는 공격 시나리오별 수행 기간, 테스트 우선순위, 운영 영향이 큰 테스트의 수행 시간대, 중간 점검 시점, 결과 정리 및 재검증 일정을 포함하는 것이 바람직하다. 특히 운영 환경에서 테스트를 수행하는 경우에는 이용자 영향이 적은 시간대를 선택하고, 이상 징후 발생 시 즉시 중단하거나 조정할 수 있도록 담당자 연락 체계를 함께 마련해야 한다.

■ 레드티밍에 사용할 도구 준비

레드티밍이 현실적인 공격 시나리오를 시뮬레이션하고 결과를 효과적으로 문서화하려면, 조직은 사전에 적절한 자원을 확보하여 제공해야 한다. 우선 원활한 테스트가 이루어질 수 있도록 충분한 컴퓨팅 성능과 API 사용 예산 등 컴퓨팅 자원을 확보해야 한다. 또한, AI 시스템에 최적화된 자동화 테스트 프레임워크, 퍼징 도구, 취약점 스캐너, 로깅 플랫폼 등 레드티밍 전용 도구를 준비해야 한다. 이와 함께 사전에 정의된 테스트 범위에 따라 문서·모델 가중치·시스템 프롬프트를 포함한 시스템에 대해 블랙박스·그레이박스·화이트박스 중 적절한 수준의 접근 권한을 부여해야 한다. 아울러 레드티밍이 현실적인 공격 시나리오를 시뮬레이션할 수 있도록 앞서 구비한 전용 도구와 환경 지원 체계를 유기적으로 결합하여 제공할 필요가 있다.

■ 데이터셋 준비

레드티밍 평가를 위한 데이터와 테스트 케이스를 준비할 때는 테스트 목표 달성을 위해 전제 조건, 입력 및 예상 결과의 집합을 체계적으로 개발해야 한다. 이때 데이터셋은 대상 AI 시스템이 공식적으로 지원하는 고자원 언어뿐만 아니라, 안전 필터 우회로 사용될 수 있는 특수 인코딩을 포함하여 평가 대상 언어를 포괄적으로 정의해야 한다. 또한, AI 레드티밍 페르소나에 맞춘 다양한 입력 데이터를 구성해야 한다. 이렇게 도메인에 특화된 데이터셋을 직접 구축할 수도 있지만 리소스가 여의치 않은 경우 부록에 작성되어 있는 오픈소스 데이터셋을 활용해도 된다.

■ 법적/윤리적 고려 사항

안전하고 책임 있는 레드티밍을 수행하기 위해 실제 서비스에 대한 잠재적 피해를 최소화할 수 있는 적합한 테스트 환경을 결정하고, 시스템 관리자와 협조하여 필요한 자산을 명확히 정의한다. 또한 테스트 과정에서 발생할 수 있는 법적 쟁점을 사전에 검토하고 엄격한 교전 규칙을 준수하며, 예상치 못한 시스템 장애나 위기 상황에 신속히 대응할 수 있도록 비상 보고 절차를 철저히 마련하여 이행한다.

■ 비상 보고 절차

테스트 과정에서 발생할 수 있는 예기치 못한 시스템 동작, 중대한 장애 또는 보안 사고에 대응하기 위해 운영 위험이 허용 가능한 수준을 초과할 경우 레드팀 활동을 중단하기 위한 기준과 중대한 취약점 발견 시 즉각적인 의사소통 채널을 포함한 명확한 에스컬레이션 절차를 사전에 수립해야 한다.

또한 가정된 피해 및 영향 범위의 평가, 중단/진행 기준, 예상치 못한 동작 및 장애에 대한 수정 절차에 대해 관련 이해관계자 간 사전 합의가 이루어져야 하며, 조직 내 기존 위기관리 또는 보안 사고 대응 절차가 마련되어 있는 경우 레드팀은 해당 절차를 준수해야 한다. 이를 통해 예상치 못한 시스템 장애나 운영 위험이 발생했을 때 신속하게 상황을 에스컬레이션하고 통제할 수 있는 비상 대응 체계를 명확히 확립한다.



레드티밍 이행

1. 공격 수행
2. 영향 분석
3. 기록 관리

1 공격 수행

사전에 기획된 위협 시나리오와 비즈니스 도메인 특화 평가 지표를 바탕으로, AI 시스템의 방어력을 확인하는 실질적인 점검을 실행한다. 이 단계에서는 한정된 자원 내에서 점검의 효율성과 깊이를 동시에 확보하기 위해 ‘2단계 검증 접근법’을 적용한다.

먼저, ‘자동화 도구를 활용한 공격 표면 전수 조사’를 수행하여 광범위한 시스템 접점에 존재하는 기본적인 취약점을 빠르게 식별하고 전반적인 보안 가시성을 확보한다. 이후 도출된 결과를 바탕으로 ‘보안 전문가에 의한 고도화 점검’을 진행한다. 이 과정에서는 자동화 도구가 탐지하기 어려운 복합적인 우회 기법과 비즈니스 로직의 결함을 심층적으로 파고들어, 기업에 치명적인 타격을 줄 수 있는 핵심 리스크를 정밀하게 검증한다.

① 자동화 도구를 활용한 레드티밍

- 위협 시나리오 개발 단계에서 식별된 공격 표면 전체에 대해, 정형화된 페이로드를 대량으로 투입하여 모델의 가드레일 동작 여부를 확인
 - 대규모 페이로드 주입: 구축된 데이터셋(탈옥 템플릿, 적대적 예제)을 API를 통해 대량으로 전송하여 기본적인 보안 정책 준수 여부를 검증
 - 적응형 변이 공격: 초기 공격이 차단될 경우, Attacker LLM을 활용하여 프롬프트의 어조, 언어, 구조를 미세하게 변형하며 재시도
 - 취약점 후보 선별: 취약 여부 판단 모델을 이용해 응답의 악용 가능성 점수를 1차 판별하고, ‘성공’ 또는 ‘잠재적 위험’으로 분류된 건을 2단계 전문가 점검 대상으로 이관

자동화된 레드팀 활동의 확장 방법론으로 별도의 공격자 모델을 통한 대규모 적대적 프롬프트 자동 생성(LLM-as-an-Attacker)과 생성된 출력의 안전·품질·성능 기준 기반 자동 분류 및 평가(LLM-as-a-Judge)를 병행 운용하여 테스트의 효율성을 높일 수 있다.

② AI 레드팀 전문가 심층 레드티밍

- 자동화 도구가 뚫지 못한 가드레일이나, 비즈니스 로직과 결합된 복합 취약점을 전문가가 직접 공략
 - 맥락 기반 우회: 자동화 도구가 구현하기 힘든 정교한 ‘심층 역할극’이나 ‘경쟁 조건’을 사람이 직접 수행하여 가드레일 무력화
 - 멀티턴 공격 실행: ‘정보 수집 → 신뢰 형성 → 악성 코드 주입’으로 이어지는 LLM과의 지속적인 대화를 통해 도메인 특화 위험(금융 사기, 의료 오진 등)이 실제로 발생 가능한지 실증
 - 내부 로직 분석: 화이트박스 점검인 경우, Chain of Thought(CoT)나 어텐션 가중치를 분석하여 모델이 왜 가드레일을 무시했는지 근본 원인 규명

공격 절차 개발 단계에서는 초기 탐색적 테스트 결과를 기반으로 한 맞춤형 공격 시그니처와 페이로드를 개발한다. 만약 특정 공격 시나리오를 실제 수행하지 않기로 결정한 경우라 하더라도, 잠재적 위험성이 높은 고위험 시나리오는 향후 대책 수립과 잔여 위험 파악을 위해 최종 보고서에 명확히 기록하여 관리한다.

2 영향 분석

공격 수행 이후에는 공격의 성공 여부뿐 아니라 해당 결과가 AI 시스템에 미치는 영향을 함께 분석해야 한다. 영향 분석에서는 도메인별 기준을 활용하여 성공한 공격의 영향을 확인하고, 이론적으로 가능한 위험과 실제 점검 과정에서 확인된 영향을 구분해야 한다.

■ 중대성 평가 기준

중대성 평가 기준은 성공한 공격이 AI 시스템에 미치는 영향을 안전, 성능 및 가용성, 품질 및 신뢰성, 시스템 영향 등의 관점에서 확인하기 위한 기준이다. 영향 분석 시에는 다음 표 18 항목과 같은 관점을 고려해야 한다.

표 18 영향 분석의 중대성 평가 기준 예시

영향 유형	주요 확인 항목	확인 내용
안전 영향	실행 가능성	생성된 출력이 실제로 실행 가능한 유해 지침인지, 단순 일반 정보 수준인지 확인한다.
	신규성	AI가 기존에 없던 공격 능력을 제공하거나 악의적 행위자의 진입 장벽을 낮추는지 확인한다.
	위험도 수준	낮음: 일반 지식 수준 높음: 구체적인 실행 지원 치명적: 즉각적인 물리적 위해 가능성
성능 및 가용성 영향	리소스 포화	공격 입력으로 인해 CPU, GPU, 메모리 등 시스템 자원 사용량이 과도하게 증가하는지 확인한다.
	지연 시간 악화	정상 입력 대비 응답 시간이 크게 증가하는지 확인한다.
	심각도 수준	낮음: 미미한 영향 보통: 눈에 띄는 속도 저하 높음: 지연 시간 급증 심각: 시스템 중단 또는 서비스 거부 가능성
품질 및 신뢰성 영향	환각 심각도	오류가 단순한 세부 오류인지, 의료·법률 등 민감 영역에서 위험한 오정보로 이어질 수 있는지 확인한다.
	편향 및 공정성	특정 집단에 대한 차별적이거나 편향된 출력이 발생하는지 확인한다.
시스템 영향	측면이동	침해된 기능이나 에이전트가 다른 시스템 또는 더 높은 권한의 기능에 접근할 수 있는지 확인한다.
	연쇄적 장애	하나의 오류나 환각이 연결된 도구, 외부 시스템, 후속 업무 흐름으로 전파되는지 확인한다.
	추적 가능성 상실	수행된 동작을 특정 사용자, 세션, 이벤트와 연결해 추적할 수 있는지 확인한다.

에이전트형 AI 시스템처럼 모델 출력이 외부 도구 실행이나 시스템 상호작용으로 이어지는 경우에는 도구 호출 전 권한 검증, 실행 경계 적용 여부, 실행 과정과 결과의 기록, 작업 흐름 전반의 추적 가능성을 함께 검증해야 한다. 특히 외부 서비스, 물리적 시스템, 금융 또는 규제 대상 시스템과 연계되는 경우, 수행된 동작을 사후에 추적할 수 없는 상태는 중요한 안전·보안 결함에 해당한다.

■ 후속 결과 분석

후속 결과 분석은 모델 출력이 실제 시스템 동작으로 이어졌는지 확인하는 단계이다. 이와 함께 레드티밍 과정에서 확인된 시스템 실패 사례가 외부에 공개될 경우 발생할 수 있는 대외 영향을 검토해야 한다. 후속 결과 분석 시에는 다음 항목을 확인해야 한다.

- **실행 위험:** AI 출력이 코드, 쿼리, 명령어 등으로 이어지는 경우 실제 백엔드 시스템에서 실행되어 데이터 조화·변경, 권한 우회, 서비스 장애 등으로 연결되는지 여부 확인
- **평판 영향:** 레드티밍 과정에서 확인된 시스템 실패 사례가 외부에 공개될 경우, 조직 신뢰도와 서비스 평판에 미칠 수 있는 영향 검토

■ 근본 원인 분석

근본 원인 분석에서는 공격이 성공한 원인을 확인해야 한다. 레드팀은 취약한 시스템 프롬프트, 출력 필터링 부재, 데이터 부족, 권한 검증 미흡 등 실패 원인을 분석하고, 이후 개선 계획 수립 시 참고할 수 있도록 정리해야 한다.

3 기록 관리

LLM 레드티밍 과정에서 발생하는 기록은 식별된 취약점을 정확히 재현하고 근본 원인을 심층 분석하기 위한 핵심 데이터 자산이다. 사전에 정의된 ‘기록 항목’에 따라 점검 내역이 명확히 기재되어야만, 사후 분석 단계에서 우리 시스템에 가장 치명적인 위협 요소가 무엇인지 통계적이고 정량적으로 도출할 수 있다. 경영진은 이를 통해 보안 투자의 우선순위를 명확히 결정하고, 실무진은 신속한 시스템 개선을 위한 지표로 활용한다.

이를 위해 레드팀 활동 전 데이터 수집 계획 수립을 의무화하며, 공격 시나리오, 입력 프롬프트 (직접 및 간접 프롬프트 인젝션 포함), 시스템 응답, 모델 버전, 하이퍼파라미터, 시스템 메타데이터 등을 구조화된 형식으로 상세히 기록한다. 아울러 수집된 데이터의 재현성을 보장하고 임의적인 데이터 변조를 방지하기 위해, 데이터 접근 로그 및 무결성 검증 제어 기능을 포함한 안전한 저장 체계를 구축하여 운영해야 한다.

■ 로그 데이터 스키마

기록 관리를 위해 수집된 데이터가 평가 매트릭스와 직접 연동되도록 로그 데이터 스키마를 입력, 출력, 평가 메타데이터로 구조화하여 저장하는 것을 권장한다. 첫째, 입력 메타데이터에는 탈옥이나 시스템 프롬프트 유출과 같은 공격 목표, RAG, MCP 등의 공격 표면, 실제 사용된 페이로드 및 모델 파라미터를 포함하여 공격의 의도와 방식을 상세히 기록한다. 둘째, 출력 메타데이터에는 모델 응답 전체, 모델이 호출한 도구 및 인자 값, 응답 생성 소요 시간(지연 시간) 등 모델의 응답과 시스템 상태를 기록한다. 셋째, 평가 메타데이터에는 최종 취약 여부 판단, 악용 가능성 점수, 도메인 특화 영향 여부 및 평가자를 기록하여 검증 결과를 명확히 남긴다.

■ 증적 자료 확보

또한, 단편적인 텍스트 로그만으로는 멀티턴에 걸친 복합적인 공격 맥락이나 시각적 취약점을 온전히 설명하는 데 한계가 있다. 따라서 개발팀이 해당 문제를 정확한 환경에서 재현하여 수정할 수 있도록 지원해야 한다. 이와 동시에 경영진에게 식별된 위험의 내용과 영향을 직관적으로 전달하고 사후 추적성을 보장할 수 있도록 부인 방지가 가능한 형태의 증적 자료를 확보하는 것을 권장한다. 멀티턴 공격의 맥락 파악을 위해 취약점이 발현되기까지의 전체 대화 히스토리를 하나의 세션으로 묶어 저장하는 ‘공격 체인 스냅샷’이 필요하다. 더불어 RAG나 외부 API 서버 등 환경에 의존적인 취약점을 개발팀이 동일하게 재현할 수 있도록 파이썬 기반의 ‘재현 스크립트’를 첨부해야 하며, UI 취약점(XSS 등)은 심각도를 직관적으로 전달하기 위해 반드시 스크린샷 또는 화면 녹화 형태의 ‘시각적 증거’로 보존해야 한다.

VI

결과 보고

1. 결과 보고서 작성
2. 개선 계획 수립
3. 후속 조치

1 결과 보고서 작성

결과 보고 단계는 레드티밍 수행 결과를 체계적으로 정리하고 문서화하는 절차이며, ‘레드티밍 결과 보고서’ 작성을 핵심 과업으로 한다. 이 보고서는 발견된 취약점의 기술적 상세 내용뿐만 아니라 비즈니스 관점의 잠재적 리스크를 종합적으로 포함한다. 이를 통해 경영진의 보안 투자 및 방어 전략 의사결정을 돕고, 실무 개발팀의 신속한 후속 조치를 지원하는 핵심적인 매개체 역할을 수행한다.

성공적인 보고서는 식별된 기술적 결함이 비즈니스 연속성, 재무, 그리고 기업 평판에 미치는 영향을 명확히 설명해야 한다. 더불어 한정된 보안 자원을 효율적으로 배분할 수 있도록 조치 우선순위를 산정하고, 실무진이 즉각적으로 적용할 수 있는 구체적인 완화 방안과 취약점 조치 후의 이행 점검 프로세스를 함께 정의한다.

■ 보고서 구성 요소 및 구조

레드티밍 결과 보고서는 조직의 근본적인 보안 수준을 향상시키는 핵심 거버넌스이다. 따라서 경영진에게는 보안 투자와 리스크 관리를 위한 명확한 의사결정 기준을 제공하고, 개발 및 운영 실무진에게는 시스템의 취약점을 조치하기 위한 구체적인 기술적 개선 방안을 제시해야 한다.

성공적인 리스크 커뮤니케이션을 위해 보고서는 독자의 각기 다른 관점과 요구사항을 충족해야 한다. 이를 위해 다음의 4가지 핵심 요소를 반드시 포함하여 구조화하며, 각 요소는 결과 도출부터 후속 조치까지 이어지는 타당하고 명확한 논리적 근거를 바탕으로 작성되어야 한다.

① 레드티밍 개요

보고서를 열람하는 경영진, 감사팀, 외부 파트너 등 제3의 이해관계자가 점검의 전제 조건을 오해하지 않도록 프로젝트의 전반적인 맥락을 동기화하는 도입부이다. 정보의 나열을 지양하고, 레드티밍의 핵심 수행 목적(잠재적 보안 취약점 식별 및 체계적 방어 방안 제시)을 명확히 밝혀야 한다.

이와 함께 점검 대상 서비스의 세부 규격(버전, 아키텍처), 수행 일정, 투입된 전문 인력 등의 기본 정보를 구체적으로 기술하여 점검의 신뢰성을 확보한다. 특히, LLM 기반의 AI 애플리케이션은

일반적인 소프트웨어와 달리 모델의 업데이트, 시스템 프롬프트의 수정, 혹은 추론 파라미터의 미세한 변경만으로도 성능과 안전성 수준이 급격하게 변동하는 고유의 특성을 지닌다.

따라서 테스트가 진행된 당시의 레드티밍 환경을 매우 상세하게 기록해야 한다. 더 나아가, 보고서에 도출된 결과가 영구적인 안전을 보장하는 것이 아니라 특정 시점의 보안 상태를 반영한 스냅샷임을 분명히 해야 한다. 이는 향후 시스템 변경으로 인해 발생할 수 있는 보안 사고의 책임 소재를 명확히 하고, 지속적인 사후 모니터링의 당위성을 경영진에게 인식시키는 필수적인 거버넌스 절차이다.

이에 따라 요약 영역에는 점검 대상이 된 AI 시스템과 구체적인 평가 범위는 물론, 보안·안전·품질·성능 등 다각도로 접근한 평가 차원을 명확히 기술한다. 아울러 적대적 테스트를 통해 도출된 주요 결과와 이것이 조직에 미칠 수 있는 잠재적인 비즈니스 영향에 대한 개요까지 포괄적으로 포함하여 보고서의 전반적인 가시성을 확보한다.

② 레드티밍 범위

레드티밍 결과 보고서에는 점검이 이루어진 대상뿐만 아니라, 사전에 이해관계자 간의 합의를 통해 검증 범위에서 제외된 항목을 작성해야 한다. 이는 도출된 결과의 신뢰도를 보장하고 평가의 현실적인 한계를 설정하는 핵심적인 절차이다.

실무 및 법적 관점에서는 향후 점검하지 않은 영역에서 보안 사고가 발생했을 때의 책임 소재와 면책 범위를 확정하는 기준이 된다. 경영진 관점에서는 시스템에 여전히 남아 있는 잔존 리스크의 실체를 정확히 인지하고, 이를 통제하기 위한 후속 보안 대책이나 추가 자원 투입을 결정하는 판단 근거로 활용된다.

따라서 검증 범위를 제외할 때는 그 사유와 한계를 구체적으로 기재해야 한다. 예를 들어, “시스템 프롬프트 유출 위협에 대해서는 심층적인 레드티밍을 수행하였으나, 모델 학습 데이터 내 개인 정보 비식별화 검증은 개발 부서의 원본 데이터 접근 권한 미제공 사유로 점검 범위에서는 제외하였다”와 같이 기술하여 불확실성을 최소화한다.

③ 취약점 요약

취약점 요약은 경영진을 비롯하여 개발자, 서비스 기획자 등 다양한 이해관계자가 LLM의 현재 보안 태세를 직관적이고 입체적으로 파악할 수 있도록 구성하는 핵심 요약부이다. 이 장에서는

독자의 각기 다른 관점과 요구사항을 충족하기 위해 기술적 결함과 비즈니스 리스크를 균형 있게 서술해야 한다.

경영진을 위해서는 식별된 취약점이 조직에 미치는 파급력, 예를 들어 “대규모 고객 개인 정보 유출 리스크”나 “브랜드 평판 훼손”과 같은 비즈니스 임팩트를 명확히 제시한다. 반면, 보안 및 개발 실무진을 위해서는 “RAG 파이프라인 내 간접 프롬프트 인젝션 취약”과 같이 해당 리스크를 유발하는 기술적인 핵심 원인을 함께 작성해야 한다.

이러한 다각적인 요약을 통해 경영진은 서비스의 안전한 배포 여부 및 추가 보안 투자를 신속하게 결정할 수 있으며, 실무진은 취약점 조치의 우선순위를 설정하고 필요한 자원 투입 규모를 즉각적으로 판단하여 실행에 옮길 수 있다.

요약 항목에는 아래 표 19의 항목이 구조화된 형태로 포함되어야 한다.

표 19 요약 구성 항목

구성 항목	주요 내용
대상 AI 시스템	점검 대상 시스템의 명칭, 버전, 아키텍처 유형(예: RAG 기반, 에이전트형 등)
평가 범위	점검이 수행된 계층(데이터, 모델, 애플리케이션, 인프라) 및 제외 항목
평가 차원	보안, 안전, 품질, 성능 중 해당 평가가 집중한 차원
주요 결과	식별된 주요 취약점 및 공격 시나리오 요약, 위험 등급별 건수
잠재적 비즈니스 영향	잠재적인 재무 손실, 법적 책임, 서비스 중단, 평판 훼손 가능성

보고서 요약 항목에는 점검 대상이 된 AI 시스템과 구체적인 평가 범위는 물론, 보안·안전·품질·성능 등 다각도로 접근한 평가 차원을 명확히 기술하고 주요 결과와 잠재적인 비즈니스 영향에 대한 개요를 포함한다. 또한, 보다 체계적인 위험 관리를 위해 ① 테스트된 AI 시스템 및 그 범위, ② 확인된 취약점 및 공격 시나리오, ③ 위험 우선순위 지정 및 영향 분석에 대한 입력, ④ 완화·권고 사항이 유기적으로 연결된 구조화된 보고 형식을 갖추어 작성한다.

④ 항목별 레드티밍 상세

항목별 레드티밍 상세 내역은 개발 및 보안 실무자가 정확한 데이터와 객관적 증거를 바탕으로 시스템의 취약점을 신속하고 근본적으로 조치할 수 있도록 구체적인 정보를 제공하는 핵심 영역이다. 경영진 관점에서는 식별된 리스크가 얼마나 확실한 근거에 기반하고 있는지 확인하는 신뢰 지표가 되며, 실무진 관점에서는 즉각적인 시스템 패치를 위한 명확한 작업 지시서 역할을

수행한다. 따라서 이 장에서는 단순히 취약점이 존재한다는 사실을 서술하는 데 그쳐서는 안 된다. 개발팀이 동일한 환경에서 문제를 즉각적으로 확인하고 분석할 수 있도록, 실제 공격에 사용된 ‘재현 가능한 페이로드’와 화면 스크린샷, 시스템 로그 등의 ‘객관적 증적 자료’를 필수적으로 포함해야 한다. LLM의 비결정적 응답 특성을 고려할 때, 오류 재현은 매우 까다로운 작업이다. 그러므로 특정 취약점이 어떤 맥락과 사전 조건에서 발현되는지에 대한 상세한 환경 정보가 반드시 함께 제공되어야만 서비스의 정확한 수정과 재발 방지가 가능하다.

표 20 문서화 항목 예시

항목	세부 내용
취약점 식별 정보	취약점 명칭, 위협 분류(예: 탈옥, 프롬프트 인젝션, 에이전트 하이재킹), 위험 등급
공격 시나리오	실행된 구체적인 공격 시나리오(예: RAG 지식베이스 오염, 에이전트 인증 우회) 및 사용된 페이로드
영향 분석	취약점이 비즈니스 연속성, 개인 정보 보호, 법적 책임, 서비스 신뢰성에 미치는 영향

상세 결과 항목에는 확인된 보안 취약점과 더불어 에이전트 인증 우회, RAG 지식베이스 오염 등 실행된 구체적인 공격 시나리오를 명확하게 기록한다. 이와 함께 해당 공격들이 성공했을 때 시스템과 비즈니스에 미치는 잠재적 피해 수준을 파악할 수 있도록, 도출된 영향 분석 결과까지 누락 없이 포괄적으로 문서화한다.

2

개선 계획 수립

■ 위험 평가 및 우선순위 선정

레드티밍을 통해 식별된 다수의 취약점 모두에 동일한 보안 자원을 투입하여 즉각적으로 조치하는 것은 현실적으로 불가능하며, 기업 운영 측면에서도 비효율적이다. 따라서 한정된 보안 예산과 실무 인력을 최적화하기 위해서는 각 취약점의 ‘발생 가능성’과 기업 비즈니스에 미치는 ‘영향도’를 종합적으로 평가하는 위험도 매트릭스 분석을 우선 시행할 것을 권장한다. 경영진과 보안 실무진은 이 매트릭스 분석 결과를 바탕으로, 비즈니스 연속성이나 브랜드 평판에 치명적인 타격을 줄 수 있는 핵심 위협부터 순차적으로 대응해 나가는 전략적인 조치 우선순위를 확립한다.

표 21 조치 우선순위 등급표 예시

우선순위	등급	판단 기준	조치 기한
매우 높음	Critical	공격 시도가 쉽고, 성공 시 법적 책임이나 금전적 피해와 같은 중대한 피해가 발생하는 경우	즉시 조치 (서비스 중단 혹은 배포 보류)
높음	High	공격 시도는 어려우나, 성공 시 법적 책임이나 금전적 피해와 같은 중대한 피해가 발생하는 경우	필수 조치 (배포 전 필수 조치)
중간	Medium	특정 조건 하에서만 발생하며, 피해가 제한적인 경우	패치를 통한 조치 (배포 후 조치 가능)
낮음	Low	공격 성공이 매우 어렵고, 피해가 미미한 경우	모니터링 대상 (별도의 조치 없이 모니터링)

3 후속 조치

이행 점검은 결과 보고서에서 식별된 취약점에 대하여 실무 개발팀이 적용한 보안 패치와 개선 방안이 시스템에 효과적으로 반영되었는지 최종 검증하는 절차이다. 후속 조치의 범위와 우선순위는 식별된 위험의 수준, 서비스 영향도, 조직의 운영 환경과 가용 자원을 고려하여 결정할 수 있다.

이 단계에서는 보안성과 서비스 품질을 동시에 보장하기 위해 두 가지 핵심 테스트를 병행한다. 첫째, 기존에 발견되었던 보안 취약점이 우회 경로 없이 근본적으로 제거되었는지 확인하는 ‘재검증’을 수행한다. 둘째, 보안 강화 조치(안전 필터 추가 등)로 인해 인공지능 모델의 본래 답변 성능이나 서비스의 유용성이 과도하게 훼손되지 않았는지 평가하는 ‘회귀 테스트(Regression Testing)’를 진행한다.

■ 취약점 조치 확인

개발팀의 보안 패치 및 개선 작업이 완료되면, 레드팀은 기존에 성공했던 공격 시나리오를 재수행하여 시스템의 방어 기제가 의도대로 완벽하게 작동하는지 검증한다. 이 단계는 비즈니스 환경에 치명적인 위험이 될 수 있는 잔존 리스크가 완전히 제거되었는지 확인하는 필수적인 보안 품질 보증 절차이다. 취약점의 근본적인 해결 여부를 판단하기 위해 다음 두 가지 관점의 점검을 차례로 수행한다.

- **동일 페이로드 재공격:** 이전에 사용했던 공격 프롬프트를 그대로 주입했을 때, 모델이 안전하게 거절하는지 확인
- **우회 공격 시도:** 개발팀이 단순 키워드 필터링으로만 조치했을 경우를 대비하여, 공격 고도화 전략(난독화, 역할극 등)을 사용하여 변형된 공격을 시도

■ 과잉 방어 방지

보안 취약점을 조치하는 과정에서 안전 필터나 제약 조건을 과도하게 강화할 경우, AI 모델이 사용자의 정상적인 요청조차 유해한 것으로 오인하여 답변을 거절하는 ‘과잉 방어’ 현상이 발생할 수 있다. 이는 비즈니스 관점에서 서비스의 핵심 가치와 사용자 경험을 심각하게 훼손하는 결과로 이어진다. 반대로 저하된 사용성을 복구하기 위해 안전장치를 무리하게 완화하면 조치했던 보안 취약점이 다시 노출되는 딜레마에 빠지게 된다. 일반적으로 서비스의 전반적인 성능과 품질을 검증하는 것은 품질 보증 부서의 고유 업무로 간주된다. 그러나 ‘비즈니스 유용성을 해치지 않는 최적의 균형점에서 시스템의 안전성을 확보’하는 것 역시 레드티밍과 후속 조치가 지향하는 본질적인 목표이다. 따라서 보안 패치가 적용된 이후에는 취약점 제거 여부를 확인하는 것뿐만 아니라, 모델의 정상적인 기능 작동 여부를 확인하는 사용성 점검(회귀 테스트 등)을 병행하는 것이 바람직하다. 다만, 치명적인 제로데이 취약점 대응과 같이 서비스 배포가 매우 시급한 상황이거나 프로젝트 일정이 촉박한 경우에는, 비즈니스 연속성을 고려하여 해당 사용성 점검의 깊이와 범위를 유연하게 조율하여 선택적으로 수행할 수 있다. 이러한 과잉 방어를 예방하고 보안 패치의 효과를 원만하게 확인하기 위해, 실무 부서에서는 다음과 같은 점검 절차를 활용하는 것을 권장한다.

- **정상 질의 테스트:** “실제 사이트 해킹 방법”과 같은 악성 요청을 차단하려다 “화이트해커 교육 자료”나 “보안 취약점 점검 가이드”와 같은 합법적인 정상 질의까지 차단하지 않는지 확인
- **성능 벤치마크:** 안전 조치 적용 전후의 응답 속도, 정확도, 창의성 지표를 비교하여 서비스 품질 저하가 허용 범위 이내인지 평가

■ 지속적인 모니터링 체계 전환

레드티밍은 단발성 보안 이벤트가 아닌, 지속적인 거버넌스 및 리스크 관리 활동이다. AI 모델은 배포 이후에도 지속적인 학습과 업데이트를 거치며, 이를 노리는 신종 공격 기법 또한 매일 진화하고 있다. 따라서 배포 전 특정 시점에만 수행하는 정적인 보안 점검만으로는 기업의 비즈니스

연속성과 서비스 신뢰성을 완벽히 보장하기 어렵다. 이러한 한계를 극복하기 위해, 조직은 실제 서비스 운영 환경에서 발생하는 보안 위협을 실시간으로 감지하고 대응하는 ‘지속적 모니터링 체계’로 전환해야 한다. 이 체계가 정착되면, 서비스 운영 중 발생하는 새로운 형태의 우회 공격이나 변형된 적대적 프롬프트 인젝션 시도에 대해서도 즉각적인 방어 태세를 갖추고 신속한 후속 조치를 수행할 수 있다. 지속적 모니터링 체계를 구축하고 실질적인 보안 가치를 창출하기 위해, 실무 환경에서는 다음과 같은 핵심 통제 방안을 적용할 수 있다.

- **가드레일 운영:** 사용자 입력과 서비스의 출력 사이에서 실시간으로 유해성을 검사하고 차단하는 보안 레이어 구축
- **정기적 자동화 점검:** 자동화 스캐닝 도구를 서비스 제공 및 배포 과정(CI/CD) 파이프라인에 통합하여, 모델 버전이 업데이트될 때마다 기본 안전성 검사를 자동 수행

조직은 취약점 조치 이후에도 동일 공격의 재현 여부, 변형 공격 가능성, 정상 기능 저하 여부를 함께 확인하는 것이 바람직하다. 다만 후속 조치의 범위와 수준은 시스템 중요도, 취약점 심각도, 서비스 영향, 가용 인력과 일정 등 조직의 상황을 고려하여 결정할 수 있다. 또한 확인된 공격 시나리오와 조치 결과를 향후 자동화 점검, 회귀 테스트, 모니터링 기준에 반영하여 레드티밍 결과가 일회성 조치에 그치지 않도록 관리할 것을 권장한다.

■ 취약점 신고·조치·공개 제도(CVD/VDP) 연계

레드티밍에서 발견한 취약점은 조직 내부의 조치에 그치지 않고, 외부의 취약점 신고·조치·공개 제도와 연계하여 관리할 수 있다. 취약점 신고·조치·공개 제도(CVD/VDP)는 기업·기관이 점검 허용 범위와 신고 절차 등을 외부에 공개하고, 선의의 정보보호 연구자가 그 범위 안에서 취약점을 발굴·신고하면 기관이 이를 접수·조치한 뒤 공개하는 제도이다. 국내에서도 이러한 제도의 도입이 추진되고 있어, 제도가 정착되면 레드티밍으로 확인된 취약점에 대해서도 정보보호 연구자의 신고와 기관의 조치가 보다 원활하게 이루어질 수 있을 것으로 기대된다.

부 록

1. 레드티밍 체크리스트
2. 레드티밍 점검 도구
3. 레드팀 인력 직무기술서(JD)
4. 레드팀 활동과 관련된 문서의 예

부록1 레드티밍 체크리스트

단계	구분	점검 항목	[YES/NO/미해당] □ □ □
레드티밍 거버넌스와 팀구성	레드팀 구성	레드티밍 목적과 범위에 따라 PM, AI 레드팀 전문가, 보안 테스트 전문가, AI 엔지니어, AI 법률 자문가, 도메인 전문가 등 필요한 역할을 정의하였는가?	□ □ □
	역할과 책임	레드팀 구성원별 역할, 책임, 의사결정 권한, 보고 책임을 명확히 지정하였는가?	□ □ □
	전문성 확보	대상 AI 시스템의 구조, 데이터 흐름, 도메인 위험, 관련 법·규제 검토에 필요한 전문성을 확보하였는가?	□ □ □
	교육	레드팀 구성원을 대상으로 시스템 이해, AI 보안 공격 기법, 도메인별 위험, 윤리 및 교전 규칙 교육을 수행하였는가?	□ □ □
	심리적 지원	유해·민감 콘텐츠 노출 가능성을 고려하여 레드팀 구성원의 심리적 부담 완화 및 보호 절차를 마련하였는가?	□ □ □
	활동 시기	출시 전 초기 검증, 출시 후 정기 점검, 모델·프롬프트·데이터 변경 후 재검증 시점을 정의하였는가?	□ □ □
	자원 확보	레드티밍 수행에 필요한 인력, 예산, 테스트 계정, API 사용량, 자동화 도구, 로그 접근 권한을 확보하였는가?	□ □ □
레드티밍 준비	사전 협의	개발팀, 보안팀, 운영팀, 법무·개인 정보 담당자 등 주요 이해관계자와 레드티밍 목적과 범위를 사전 협의하였는가?	□ □ □
	교전 규칙	허용되는 테스트 범위, 금지 행위, 데이터 사용 기준, 보고 절차, 중단 조건을 포함한 교전 규칙을 수립하였는가?	□ □ □
	목표 설정	레드티밍 목표를 구체적이고 측정 가능하며 달성 가능하고 관련성 있으며 기한이 정해진 기준으로 설정하였는가?	□ □ □
	범위 설정	레드티밍 범위가 핵심 AI 모델뿐 아니라 데이터, 애플리케이션, API, RAG, 에이전트, 외부 연계, 인프라 등 AI 시스템 전체를 고려하도록 설정되었는가?	□ □ □
	제외 범위	실제 고객 데이터, 운영 장애 가능 영역, 제3자 서비스, 법적 제한 영역 등 제외 또는 별도 승인 대상 범위를 명확히 하였는가?	□ □ □
	접근 수준	대상 시스템의 특성과 정보 제공 가능 범위에 따라 블랙박스, 그레이박스, 화이트박스 접근 수준을 결정하였는가?	□ □ □
	평가 기준	공격 성공률, 차단 거부율, 재현율, 민감 정보 노출 건수, 응답 지연 등 정량 평가 기준을 마련하였는가?	□ □ □
	위험 등급	영향도, 악용 가능성, 연계 시스템 영향, 정책 위반 수준, 대응 가능성을 고려한 정성 평가 및 위험 등급 기준을 마련하였는가?	□ □ □

단계	구분	점검 항목	[YES/NO/미해당] □ □ □
위협 시나리오 개발	공격 표면 식별	채팅 UI, API, 파일 업로드, RAG, 벡터 DB, 외부 도구, 에이전트, 로그, CI/CD 등 공격자가 영향을 줄 수 있는 접점을 식별하였는가?	□ □ □
	중요 접점 우선순위	외부 시스템 호출, 데이터 조회, 코드 실행, 이메일 발송 등 실제 시스템 동작으로 이어질 수 있는 접점을 우선 검토하였는가?	□ □ □
	위험 분류	데이터 및 모델 위험, 에이전트 및 공급망 위험 등 대상별 주요 위험을 분류하였는가?	□ □ □
	페르소나 정의	일반 사용자, 악의적 사용자, 내부 사용자, 도메인 전문 지식 보유자, 자동화 도구 활용자 등 필요한 AI 레드팀 페르소나를 정의하였는가?	□ □ □
	페르소나 속성	각 페르소나의 의도, 접근 수준, 전문성, 활용 자원, 주요 공격 방식을 문서화하였는가?	□ □ □
	시나리오 구성	공격 표면, 페르소나, 공격 유형, 사전 조건, 실행 절차, 판정 기준, 영향도, 기록 항목을 포함하여 공격 시나리오를 작성하였는가?	□ □ □
	재현 가능성	공격 시나리오가 실제 테스트 환경에서 반복 수행 및 재현 가능한 수준으로 구체화되었는가?	□ □ □
환경 준비	테스트 환경	운영, 스테이징, 개발 환경 중 테스트 목적과 위험 수준에 적합한 환경을 결정하였는가?	□ □ □
	영향 통제	서비스 중단, 데이터 훼손, 외부 시스템 영향, 비용 급증 등을 방지하기 위한 제한 조건을 설정하였는가?	□ □ □
	자산 요청	테스트 계정, API 키, 로그, 모니터링 정보, 테스트 데이터, 도구 사용 권한 등 필요한 자산을 사전에 요청·확보하였는가?	□ □ □
	최소 권한	테스트 자산은 최소 권한 원칙에 따라 제공되며, 운영 비밀값과 민감 데이터가 불필요하게 노출되지 않도록 관리되는가?	□ □ □
	일정 수립	공격 시나리오별 수행 기간, 우선순위, 운영 영향이 큰 테스트의 수행 시간대, 중간 점검 및 재검증 일정을 수립하였는가?	□ □ □
	도구 준비	자동화 테스트 프레임워크, 퍼징 도구, 취약점 스캐너, 로깅 플랫폼, 협업 도구 등 레드티밍 도구를 준비하였는가?	□ □ □
	법적·윤리적 검토	개인 정보, 기밀 정보, 제3자 서비스, 저작권, 유해 콘텐츠 생성 등 법적/윤리적 고려 사항을 검토하였는가?	□ □ □
	비상 보고 절차	중대한 취약점, 예상치 못한 장애, 민감 정보 노출, 운영 위험 초과 시 즉시 보고 및 중단할 수 있는 비상 절차를 마련하였는가?	□ □ □
레드티밍 이행	공격 수행	사전에 정의한 공격 시나리오와 교전 규칙에 따라 공격을 수행하였는가?	□ □ □
	자동 레드티밍	정형화된 페이로드, 공개 데이터셋, 자동 증강 기법, LLM-as-Attacker/Judge 등을 활용하여 대량·반복 테스트를 수행하였는가?	□ □ □
	HITL 검토	자동 판별 결과가 불확실하거나, 모델 간 판단이 불일치하거나, 심각도·신규성이 높은 항목을 사람이 재검토하였는가?	□ □ □

단계	구분	점검 항목	[YES/NO/미해당] □ □ □
	AI 레드팀 전문가 심층 레드티밍	자동화 도구로 발견하기 어려운 논리적 결함, 컨텍스트 기반 공격, 도메인 특화 우회 가능성을 전문가 레드팀이 점검하였는가?	□ □ □
	결과 판정	각 공격 결과를 사전 정의한 정량·정성 평가 기준과 위험 등급에 따라 판정하였는가?	□ □ □
	영향 분석	공격 결과가 AI 시스템에 미치는 영향을 분석하였는가?	□ □ □
	중단 기준 적용	운영 위험, 민감 정보 노출, 서비스 장애 등 중단 조건에 해당하는 상황이 발생했을 때 즉시 중단·보고 절차를 적용하였는가?	□ □ □
기록 관리	로그 수집	입력값, 출력값, 모델 버전, 시스템 프롬프트 버전, 도구 호출, API 응답, 오류 로그, 응답 지연 시간 등 테스트 로그를 수집하였는가?	□ □ □
	구조화 저장	수집된 결과를 평가 기준, 공격 시나리오, 위험 등급, 개선 과제와 연계될 수 있도록 구조화하여 저장하였는가?	□ □ □
	증적 확보	멀티턴 대화 전체 맥락, 스크린샷, 화면 녹화, 실행 스크립트, 재현 절차 등 부인 방지 가능한 증적을 확보하였는가?	□ □ □
	기밀 관리	취약점, 유해 출력, 민감 정보, 내부 시스템 정보가 포함된 기록물에 접근 통제와 보관·파기 기준을 적용하였는가?	□ □ □
결과 보고	보고서 구성	결과 보고서에 수행 목적, 대상, 범위, 일정, 참여 인력, 접근 수준, 수행 방법론, 평가 기준을 명확히 기술하였는가?	□ □ □
	취약점 설명	발견된 취약점별로 공격 경로, 재현 절차, 성공 조건, 영향도, 관련 증적을 포함하였는가?	□ □ □
	비즈니스 영향	취약점이 기밀성, 무결성, 가용성, 법적 책임, 서비스 연속성, 평판에 미치는 영향을 설명하였는가?	□ □ □
	우선순위	위험 등급과 비즈니스 영향도를 기준으로 조치 우선순위를 제시하였는가?	□ □ □
	완화 방안	시스템 프롬프트 개선, 가드레일 보완, 권한 축소, 필터링 강화, 로그·모니터링 개선 등 구체적인 완화 방안을 제시하였는가?	□ □ □
개선 계획 수립	개선 과제	발견된 취약점을 담당 부서, 조치 내용, 완료 기한, 검증 기준이 포함된 개선 과제로 전환하였는가?	□ □ □
	재검증 계획	개선 조치 후 이전에 성공한 공격 시나리오를 재현하여 취약점 완화 여부를 확인하는 재검증 계획을 수립하였는가?	□ □ □
	정상 기능 확인	취약점 조치 후 정상 질의, 주요 업무 흐름, 연계 시스템 연동이 기존 목적대로 작동하는지 확인하였는가?	□ □ □
	회귀 테스트	모델, 프롬프트, 데이터, 가드레일, 외부 도구 변경으로 인해 새로운 취약점이 발생하지 않았는지 회귀 테스트를 수행하였는가?	□ □ □
	운영 반영	재검증 결과와 개선 내역을 보안 정책, 개발 프로세스, CI/CD 점검, 모니터링 체계에 반영하였는가?	□ □ □
	지속 점검	정기적·지속적 레드티밍 계획을 수립하고, 신규 위험·시스템 변경 운영 이슈 발생 시 점검 범위를 갱신하도록 관리하였는가?	□ □ □

부록2 레드티밍 점검 도구

가. DeepTeam

DeepTeam은 Confident-AI팀이 개발한 도구로써, 자동화된 LLM 레드티밍에서 사용 편의성과 보안 검증 능력을 제공한다. 500개 이상의 공격을 1분 내에 수행할 수 있으며, 모델에 대한 빠른 스캔과 MLLM(Multimodal Large Language Model) 보안 연구에 유용하게 활용할 수 있다. 짧은 코드로 40개 이상의 취약점 유형에 대해 10여 가지 공격 기법을 자동으로 시뮬레이션할 수 있으며, 특히 로컬 환경에서 완전히 독립적으로 실행되어 데이터 프라이버시를 보장한다. 또한 DeepEval 생태계와 호환이 가능하며 일반적인 LLM 평가부터 레드티밍까지 한 번에 수행이 가능한 장점이 있다.

표 22 DeepTeam 특징

구분	설명
공격자	싱글턴-프롬프트 인젝션/Leetspeak 등, 멀티턴-Linear/Tree/Crescendo 등 20가지 공격 기법 제공
오케스트레이션	YAML 파일로 오케스트레이션을 위한 config 관리
예산·레이트리밍 제어	동시성(max_concurrent)-공격 횟수 옵션만 제공
판별자	LLM 기반 판별(GPT, Claude 등)은 제공
HITL	별도의 사람 검수 기능 미지원
메모리·로그·재현	공격 결과 JSON 로컬 저장을 지원하며 공격에 사용된 프롬프트(reuse_simulated_attacks=True)를 저장할 수 있어 재채점 및 재현 기능 지원
대상 커넥터	OpenAI·Gemini·Azure·Custom LLM 등 지원
취약성 템플릿·가드레일	40+ 취약성, 10+ 공격 프리셋 및 OWASP LLM Top10 2025·인공지능 리스크 관리 프레임워크 「Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile(NIST, '24)」(예정) 매핑을 제공
RAG·에이전트 특화	RAG 데이터나 외부 저장소에 대한 위험을 직접적으로 탐지하지는 않지만 RAG·에이전트 파이프라인 중단 테스트는 가능
확장성(모듈성)	DeepEval 인터페이스를 통해 커스텀 평가 모델과 메트릭 구성이 가능
운영 적합성	로컬 실행, YAML 기반 자동화가 제공되어 운영에 용이하지만 Docker 이미지, 예시 파이프라인은 미제공
비용·인력	중급(오픈소스·로컬 실행 및 간단한 콜백/CLI를 사용할 수 있는 인력이 필요하며 낮은 비용으로 시작 가능)
기술 요건	Python, YAML 편집, LLM 제공자 크리덴셜/환경변수, 간단한 비동기/동시성 파라미터 이해
라이선스	Apache-2.0

나. PyRIT

PyRIT은 마이크로소프트 AI 레드팀이 100회 이상의 실제 운영을 통해 검증된 경험 기반의 프레임워크로, 기존 마이크로소프트 팀의 수동 레드티밍을 자동화 레드티밍으로 전환시키며 효율성을 높이는 데 일조한 도구이다. 6가지 핵심 요소(메모리, 공격 대상 모델, 공격자, 데이터셋, 판별자, 오케스트레이터)로 구성된 모듈식 설계를 통해 편리한 커스터마이징을 제공한다. 또한 마이크로소프트의 자동화와 사람의 전문성의 조화라는 철학을 기반으로 반복적인 작업은 자동화하면서 전략 수립과 심층 분석에서는 사람의 역할을 중시하는 HITL의 접근법을 제공한다.

표 23 PyRIT 특징

구분	설명
공격자	프롬프트 변환(Converters), 시드/템플릿(Jailbreak templates), 에이전트 기반 멀티턴 우회 제공
오케스트레이션	멀티턴 대화 상태를 관리하면서 공격 시퀀스를 실행하고, 공격자, 판별자를 하나의 오케스트레이션으로 묶어 반복 실험을 자동화하는 기능을 제공
예산·레이트리미트 제어	비동기 실행(run_attack_async)과 상태·로깅 기능만 제공
판별자	ML/임베딩/LLM 기반, 규칙 기반 평가가 적용 가능하며, 여러 판별자를 조합하는 앙상블도 지원
HITL	모호한 사례를 사람이 직접 판별할 수 있는 기능을 제공
메모리·로그·재현	DuckDB/Azure SQL 메모리, 로컬 저장소에 저장하는 기능을 제공
대상 커넥터	OpenAI·Gemini·Azure·Custom LLM 등 지원
취약성 템플릿·가드레일	시드 프롬프트·워크플로·필터 연동 가능, 공개된 가이드라인과 매핑은 제공하지 않음
RAG·에이전트 특화	RAG·에이전트형 시스템에서 발생하는 위험에 대한 평가를 다양한 모듈의 조합으로 가능
확장성(모듈성)	공격자, 판별자, 오케스트레이션, 취약점 유형 등을 모듈식으로 추가/확장 가능
운영 적합성	로컬 실행 지원, 멀티벤더/HTTP 대상 추상화, Docker/CI 연동 사례 및 API 통합 리포지토리 등이 가능
비용·인력	중급~고급(Python 패키지이지만 메모리(기록) DB 구성(로컬 SQLite~Azure SQL), 브라우저 대상(Playwright), 스코어러/워크플로 조합 등 환경 준비가 필요하기에 이를 다룰 수 있는 인력과 상대적으로 높은 비용이 필요)
기술 요건	Python(비동기 I/O 포함), SQL 스키마/스토리지, 웹 자동화(Playwright), 클라우드(Azure) 구성·권한, 대량 실험 운영
라이선스	MIT

다. PromptFoo

PromptFoo는 마이크로소프트, 디스코드, Shopify 등 대기업에서 실전 검증된 테스트 경험에 있는 레드티밍 자동화 도구이다. 해당 도구는 편리한 YAML 설정과 CLI/웹 UI의 듀얼 인터페이스로 개발자들이 복잡한 코딩 없이도 자동화된 레드티밍을 수행할 수 있게 한다. 여러 모델과 프롬프트 변형을 선언적으로 비교·검증할 수 있고, 테스트 케이스 및 평가 지표(정확도, 응답 지연, 비용, 보안 취약성 등)를 구축하여 반복 가능한 품질 보증 파이프라인에 통합하기 좋다.

표 24 PromptFoo 특징

구분	설명
공격자	탈옥, 프롬프트 인젝션, 다국어 공격 등 다양한 공격 기법을 지원
오케스트레이션	공격자와 판별자 모델, 평가 메트릭을 파이프라인으로 묶어 반복 실험을 자동화하는 기능 제공
예산·레이트리미ت 제어	동시성, 요청/분당(RPM) 제한 대응, 재시도·백오프, 샘플링·중복 제거(캐시 포함)로 비용·속도를 통제하는 설정과 실행 옵션을 제공
판별자	규칙 기반과 LLM 기반 판별을 함께 구성해 앙상블 스코어러로 일관된 채점을 수행 가능
HITL	고위험·경계 사례를 사람이 웹뷰어를 통해 직접 판정하거나 재채점(regrade)·override할 수 있도록 구성
메모리·로그·재현	요청/응답/점수와 다양한 메타데이터를 로컬 DB와 파일로 기록 및 저장, 재채점(regrade)·재현(reproduce) 기능 지원
대상 커넥터	OpenAI·Gemini·Azure·Custom LLM 등 지원
취약성 템플릿·가드레일	50개 이상의 보안 취약점 유형(OWASP, NIST)을 테스트할 수 있는 플러그인을 제공
RAG·에이전트 특화	RAG·에이전트 아키텍처 전용 워크플로를 제공하여 파이프라인 전반을 자동 검증 가능
확장성(모듈성)	커스텀 공격자·판별자·공격 전략·취약점을 모두 모듈식으로 확장할 수 있는 구조를 제공
운영 적합성	로컬 실행, 오픈 라이선스, 멀티벤더 지원, Docker/CI 연동을 모두 제공
비용·인력	초·중급(개발자 친화적) 로컬 도구, 간단한 선언형 설정과 CLI/CI 통합으로 적은 인력 및 비용으로 운영 가능)
기술 요건	Node/JS(또는 최소한 npm 사용), YAML, 간단한 스크립팅(JS/Python)으로 커스텀 평가 작성, 다양한 LLM 자격 증명 관리
라이선스	MIT

라. Inspect AI

Inspect AI는 정부 주도(UK AI Safety Institute) 실전 운영에서 나온 평가 워크플로를 오픈소스로 제공한 도구이다. 레드티밍에 필요한 데이터셋, 공격자(Solver)와 판별자(Scorer)와 같은 모듈들을 유연하게 조합할 수 있는 아키텍처로 구성하여 다양한 공격 시나리오를 생성할 수 있다. 또한 샌드박스 환경에서 안전한 적대적 코드 실행을 지원하며 에이전트 기반 평가를 통해 CoT와 도구를 사용한 복합적인 패턴으로 공격이 가능하다. 그리고 다중 로그 뷰어 지원과 같은 포괄적인 로깅 시스템으로 모든 레드티밍 과정을 재현 가능하게 기록할 수 있다. 정부 차원에서 지원을 받는 유일한 오픈소스 AI 레드팀 도구이기에 지속적인 업데이트와 공신력 있는 자동화 도구인 것이 가장 큰 특징이다.

표 25 Inspect AI 특징

구분	설명
공격자	Solver 기능을 통해 프롬프트 생성은 지원하나, 자체적인 탈옥 프롬프트 생성기는 지원하지 않음
오케스트레이션	TaskState, handoff 등의 함수를 통해 에이전트 간의 대화 및 상태를 확인 가능
예산·레이트리미트 제어	예산 및 레이트리미트 제어 가능
판별자	Scorer 기능을 통해 Solver의 공격 결과를 평가하여 성공 여부를 측정 가능
HITL	HITL 워크플로를 지원
메모리·로그·재현	평가 중의 요청/응답/점수 및 각종 메타데이터를 구조화해 파일(로컬·원격)로 저장하고, 뷰어·CLI·Python API로 열람·변환·재채점·복원 실행이 가능
대상 커넥터	OpenAI·Gemini·Azure·Custom LLM 등 지원
취약성 템플릿·가드레일	평가 프레임워크써 취약성 시나리오를 Solver, Scorer로 구현 가능하지만 OWASP, NIST 등에 맞춘 매핑은 사용자가 직접 구성하는 방식
RAG·에이전트 특화	데이터 포이즈닝, 외부 스토리지 경유, 도구 호출 등 파이프라인 전반을 샌드박스과 에이전트 도구를 통해 구성하여 검증 가능
확장성(모듈성)	모듈로 정의해 조립할 수 있도록 API와 확장 포인트를 제공
운영 적합성	로컬 실행, 오픈 라이선스, 멀티벤더 모델, 컨테이너/CI 파이프라인 연동 가능
비용·인력	중급(Python, 컨테이너/쿠버네티스 기술 스택이 있는 인력이 필요하며, 로컬 모델 사용 시 비용은 높아짐)
기술 요건	Python(비동기·타이핑), 컨테이너(Docker/K8s/가상화) 이해, 도구/에이전트 설계, 다양한 모델 크리덴셜/옵션 관리
라이선스	MIT

마. Garak

Garak(Generative AI Red-teaming & Assessment Kit)은 NVIDIA가 개발한 오픈소스 도구로, LLM의 보안 취약점을 체계적으로 탐지하고 평가하기 위해 설계되었다. Garak은 LLM 배포 및 운영 시 발생 가능한 다양한 위험성을 probe라는 공격 시뮬레이션을 통해 점검하며 생성기(generator), 탐지기(detector) 등의 플러그인 기반 구성 요소들이 상호 작용하여 동작한다. 최종적으로는 JSON 혹은 HTML 형태의 보고서를 제공하여 취약점이 발견된 지점과 개선 여지를 정리함으로써, 모델을 보다 안전하고 신뢰성 있게 운용할 수 있도록 돕는다.

표 26 Garak 특징

구분	설명
공격자	jailbreak·prompt injection·toxicity·hallucination 등 100+ 공격 기법, 20,000+ 프롬프트 테스트 지원
오케스트레이션	YAML 기반 config 설정, CLI 기반 자동 실행 지원
예산·레이트리밋 제어	자동 레이트리밋 처리, generations 파라미터로 프롬프트당 생성 수 제어
판별자	키워드 검색(StringDetector), ML 기반 판별(HFDetector), 임계값 기반 평가
HITL	사람 검수 기능 미지원
메모리·로그·재현	4가지 로그 형태(Screen/Report/Hit/Debug), JSONL+HTML 리포트, 프롬프트-응답 기록
대상 커넥터	OpenAI·Hugging Face·Cohere·Replicate·NVIDIA NIM·Custom API 등 20+ 플랫폼 지원
취약성 템플릿·가드레일	100+ 취약점 유형, 정적/동적/적응형 프로브, NVIDIA NeMo Guardrails 통합
RAG·에이전트 특화	일반적인 LLM 취약점에 집중, RAG·에이전트 특화 공격은 제한적
확장성(모듈성)	플러그인 아키텍처, 커스텀 프로브/판별자/생성기 구성 가능
운영 적합성	CLI 기반 자동화, NVIDIA Evals Factory 컨테이너 지원, API 통합 가능
비용·인력	초·중급(Python/CLI 기술 스택이 있는 인력이 필요하며, 초기 비용 및 운영 비용은 낮음)
기술 요건	Python/CLI 사용, 모델·게이트웨이 엔드포인트 설정, JSONL 결과 해석, 간단한 플러그인 개발(클래스 상속)
라이선스	Apache-2.0

표 27 오픈소스 데이터셋 예시

데이터셋	분류	핵심 용도	규모 및 구성	라이선스
JBB-Behaviors	일반 금지 행위·탈옥	정책 위반 유도 시나리오의 기저선 확보를 수행	• 10개의 카테고리에 대해 200개의 프롬프트-답변 쌍	MIT License
AdvBench	일반 금지 행위·탈옥	유해 지시문 기반 정렬 취약성 점검을 수행	• 유해 행위 520개의 프롬프트-답변으로 구성	MIT License
HarmBench	일반 금지 행위·탈옥	자동 레드팀 표준 평가 프레임워크로 모델-공격 교차 평가를 수행	• 3개의 대분류, 14개의 소분류로 구성 • 400개의 데이터셋	MIT License
SafetyBench	일반 금지 행위·탈옥	다범주 안전 문항으로 정량 점검을 수행	• 7개 안전 카테고리, 11,435개의 객관식 문항으로 구성	MIT License
In-the-Wild Jailbreak Prompts	일반 금지 행위·탈옥	실제 커뮤니티에서 수집된 우회 전술을 재현 평가	• 2022.12~2023.12 동안 수집한 15,140개의 프롬프트 • 1,405개의 탈옥 프롬프트 확보	MIT License
WildJailbreak	일반 금지 행위·탈옥	합성·실전 혼합으로 과거취약·과잉 거절을 동시 점검	• 4개의 유형에 대한 262K 프롬프트	ODC-BY
Anthropic HH-RLHF	일반 금지 행위·탈옥	사람 주도 레드팀 시도를 참조해 인간형 공격 패턴을 점검	• 안전한 답변(chosen)과 안전하지 않은 답변(rejected)으로 구성된 160,800개의 데이터셋	MIT License
Real Toxicity Prompts	유해 발화·혐오·모더레이션	유해 발화 유도·우회 감지 성능을 점검	• 웹 문장 기반 99,442개의 프롬프트로 구성	Apache-2.0 License
ToxicChat	오염 혐오·모더레이션	실사용 대화 맥락의 유해·탈옥 라벨링을 점검	• 유해성, 탈옥 여부가 라벨링 된 10,165개의 프롬프트	CC BY-NC 4.0
PINT Benchmark	프롬프트 인젝션·에이전트·RAG 보안	인젝션 탐지기의 종립적 성능 비교를 수행	• 5개의 카테고리에 대한 4,314개의 프롬프트 • 영어 3,016개, 그외 1,298개	MIT License
Microsoft BIPA	프롬프트 인젝션·에이전트·RAG 보안	외부 콘텐츠 기반 간접 인젝션 견고성을 평가	• 5개의 카테고리 (WebQA/EmailQA/TableQA/요약/CodeQA)	MIT License
PromptShield Dataset	프롬프트 인젝션·에이전트·RAG 보안	대규모 큐레이션 데이터로 탐지기 학습·평가를 수행	• 프롬프트 인젝션 시도 여부가 라벨링된 43,425개의 프롬프트	CC BY-ND 4.0
NotInject	프롬프트 인젝션·에이전트·RAG 보안	유해한 트리거 단어가 포함된 '정상' 샘플로 과잉방어(False Positive) 경향을 측정	• 4개의 카테고리 • 트리거 단어 개수(1, 2, 3개)별로 113개의 데이터셋 존재	MIT License
SafeRAG	프롬프트 인젝션·에이전트·RAG 보안	RAG 파이프라인 전 단계(검색·필터·생성)의 보안 취약성을 평가	• 4가지 카테고리 (Noise, Conflict, Toxicity, DoS) • 카테고리별로 약 100개의 데이터	-
RICoTA	일반 금지 행위·탈옥	실제 사용자들이 챗봇과 대화하며 시도	• 609개의 한국어 탈옥 시도를 포함한 대화 데이터셋	CC BY-SA 4.0

부록3 레드팀 인력 직무기술서(JD)

가. 리더·PM

- 레드팀 활동의 전략 수립부터 범위·예산·일정·품질 관리 및 이해관계자 간의 조정까지 전사적 레드티밍 운영을 총괄
- 주요 역할
 - 이해관계자와 협의하여 레드팀 활동의 목표, 범위, 평가 지표 설정 및 관리
 - 레드팀의 조직 구성 및 자원 배분 계획
 - 활동 일정 수립 및 프로젝트 관리
 - 윤리·법적 준수사항에 대한 관리 및 모니터링
 - 수행된 평가 결과 보고
 - 예산 관리, 외부 협력업체 관리 등
 - 레드티밍 중 발생하는 문제에 대해 의사결정
- 필수 역량
 - 리더십 및 팀 관리 능력
 - 뛰어난 의사소통 및 협상 능력
 - 프로젝트 관리 전문성(일정, 예산, 자원 관리 등)
 - 레드팀 운영 원칙과 방법론에 대한 이해
 - 위기 상황 대응 및 의사결정 능력
 - 유관 업무 경력 7년 이상
- 우대 사항
 - AI 레드팀 운영 경험
 - AI 관련 CTF 수상 경험
 - Top-tier급 학회에서 논문 발표 경험
- 핵심 플레이북
 - 기획-실행-보고-피드백의 전체 프로세스가 정의된 레드티밍 표준 운영 절차
 - 발견된 취약점의 심각도 판정 기준 표

나. AI 레드팀 전문가

- LLM의 프롬프트 기반 취약점(프롬프트 인젝션, 탈옥 등)을 설계·실행·분석하여 모델 보안성을 검증하고 대응 방안을 제안
- 주요 역할
 - 프롬프트 인젝션, 탈옥 등 적대적 프롬프트 설계 및 실행
 - 사용자 입력과 LLM 출력 처리 과정에서의 취약점 점검
 - 유해한 콘텐츠 생성이나 편향된 결과를 유도하는 프롬프트 테스트
 - 훈련 데이터나 대화 맥락에서 민감 정보 유출 시도
 - LLM 응답 분석을 통한 새로운 공격 전략 설계
 - 성공적인 공격 방식과 구체적인 프롬프트 문서화
- 필수 역량
 - 자연어 처리, AI 보안 분야 전문성
 - LLM의 언어 처리 방식에 대한 깊은 이해
 - 프롬프트 엔지니어링 및 컨텍스트 엔지니어링 능력
 - 최신 LLM 공격 기술과 연구 동향에 대한 지식
 - 유관 업무 경력 3년 이상
- 우대 사항
 - AI 레드팀 수행 경험
 - AI 관련 CTF 수상 경험
 - Top-tier급 학회에서 프롬프트·컨텍스트 엔지니어링 관련 논문 발표 경험
- 핵심 플레이북
 - 세부적으로 정리된 공격 프롬프트 라이브러리
 - LLM 응답 유형에 따른 취약점 판단 기준

다. 보안 테스트 전문가

- LLM이 포함된 서비스의 API·웹·인프라 전반을 대상으로 취약점 평가를 수행하고, 실용적 공격 시나리오를 통해 보안 리스크를 발견 및 분석

- 주요 역할

- LLM 접근(예: API 엔드포인트, 프록시, 파이프라인) API 및 인터페이스 보안성 평가
- 배포 환경 및 인프라 취약점 점검
- 데이터 저장 및 전송 과정에서의 취약점 점검
- LLM 애플리케이션의 일반적인 웹·모바일 취약점 점검

- 필수 역량

- 웹, 애플리케이션 보안 테스트 전문성
- OWASP Top 10 등 웹 취약점 분석 능력
- API 보안 및 데이터 흐름 분석 능력
- 취약점 도구 및 수동 분석 경험(예: Burp Suite, Caido 등)
- 침투 테스트 보고서 작성 능력 및 기술적 커뮤니케이션 역량

- 우대 사항

- OSCP, OSEP 등 실무 자격증 보유
- 클라우드 보안(AWS·Azure·GCP) 환경 취약점 분석 경험
- 로그·이상 탐지(IDS·EDR) 관점의 취약점 탐지 경험
- LLM 시스템과의 연동에서 오는 특수 취약점 지식(예: RAG 지식베이스 노출, chain-of-thought 노출) 보유

- 핵심 플레이북

- LLM 애플리케이션 특화 보안 점검 항목(OWASP Top 10 for LLM Application)

라. AI 엔지니어

- 모델 동작·학습 데이터 관점에서 LLM의 성능·편향·정보 유출 리스크를 분석하고, 공격 결과에 따른 모델 수준의 개선 수행

- 주요 역할

- 모델 동작 분석을 통한 아키텍처 취약점 또는 학습 데이터 편향 검증
- 모델 정확도, 일관성, 신뢰성 등 성능 지표 측정 및 분석
- 학습 데이터 내 민감 정보 또는 개인 정보 포함 여부 점검 및 정제 방안 제시
- 모델 이해를 기반으로 LLM 보안 전문가와 협업하여 공격 페이로드(적대적 프롬프트) 개선
- 자동화된 레드팀 테스트 파이프라인 설계 및 구축

- 필수 역량
 - 머신러닝, 데이터 분석 전문 기술
 - 모델 아키텍처 및 훈련 과정에 대한 이해
 - 유관 학과(AI, 통계학, 데이터 과학 등) 석사 이상
 - 유관 업무 경력 4년 이상(석사 기간 2년 포함)
- 우대 사항
 - LLM Ops 설계 및 테스트 자동화 경험
 - 모델 개발 및 LLM 관련 서비스 기획 및 운영 경험
 - Top-tier급 학회에서 논문 발표 경험
- 핵심 플레이북
 - 데이터 정제 가이드라인
 - 공격 전후의 성능 평가 지표

마. AI 법률 전문가

- LLM/AI 서비스 적용 시 준수해야 하는 법적·규제적 기준을 수립하고, 레드티밍에서 생성된 출력의 위법성·리스크를 판단하여 법적 자문 제공
- 주요 역할
 - LLM 서비스에서 고려되어야 할 기본적인 법적 사항 검토
 - 레드티밍 시, 페이로드(적대적 프롬프트)를 통해 출력된 서비스 결과의 위법성 및 윤리적 위험성 판단
 - 해당 서비스 분야에서 발생할 수 있는 위협 정의
 - 레드티밍 시 출력된 응답의 위법성 판단
 - 공정성, 편견, 차별적 콘텐츠 생성 등 사회적 영향 관점에서 모델 평가
 - 서비스 분야별 특수한 공격 시나리오 설계
- 필수 역량
 - 인공지능기본법, 개인정보보호법 등 윤리, 안전과 관련한 법적 지식 보유자
 - AI·데이터 활용과 관련된 법적 쟁점에 대한 실무 경험
 - 복잡한 기술문서를 법적 관점에서 해석·자문할 수 있는 능력
 - AI 윤리 및 책임감 있는 AI 개발 전문성

- 해당 서비스 분야의 위험 요소에 대한 이해
- 이해관계자 대상 명확한 법적 리스크 커뮤니케이션 능력
- 유관 업무 경력 3년 이상
- 우대 사항
 - 변호사 자격증 또는 관련 법률 자문 경력
 - AI·IT 기업 법무 또는 규제 대응 경험
 - 국제 규제(예: GDPR) 관련 자문 경험
 - AI 유관 윤리·안전 관련 정책(거버넌스) 수립 참여 경험
- 핵심 플레이북
 - AI 관련 법령 위반 여부를 진단할 수 있는 AI 컴플라이언스 체크리스트

바. 도메인(금융, 의료, 공공, 교육 등) 전문가

- 대상 서비스 도메인(금융, 의료, 공공, 교육, 법률 등)에 대한 전문 지식을 기반으로 실제 서비스 환경에서 발생할 수 있는 도메인 특화 리스크·위협·규제 이슈를 식별하고 테스트 시나리오 설계
- 주요 역할
 - 서비스 도메인에 특화된 규제 환경 분석
 - 레드티밍 과정에서 도메인 특화 공격 시나리오(예: 금융사기, 의료정보 오남용 등) 설계
 - 도메인 관점에서 LLM 출력의 신뢰성, 안전성, 법적 리스크 평가
 - 레드팀, AI 보안 전문가, 법률 자문가와 협업하여 평가 기준 수립
 - 테스트 결과에 대한 도메인 기반 위험 해석 및 개선 제안
 - 도메인 관련 데이터 민감도, 규제 준수 여부 검토 지원
- 필수 역량
 - 해당 서비스 분야에 대한 심층 지식 및 실무 경험
 - 도메인별 데이터 특성, 규제, 보안요건에 대한 이해
 - LLM 및 정보 보안에 대한 이해
 - 복잡한 기술적 내용(LLM 출력, 데이터 흐름 등)을 도메인 맥락에서 해석하는 능력
 - 협업 및 의사소통 능력 (AI·보안·법률·PM 등 타 직군과의 협업 필수)
 - 해당 도메인 실무 경험 3년 이상

- 우대 사항

- 관련 분야 전문 자격(예: 금융전문인, 의무기록사, 변리사, 교사, 행정사 등)
- 도메인 내 데이터 거버넌스·보안·리스크 관리 경험
- LLM 또는 AI 기술이 적용된 해당 산업 서비스 QA 경험
- 도메인 규제 대응, 감사, 품질보증, 심사 경험

- 핵심 플레이북

- 도메인별 시나리오 라이브러리
- 도메인별 정보의 중요도 등급표

부록4 레드팀 활동과 관련된 문서의 예

※ 부록4는 ISO/IEC 42119-7 표준안에 참고용으로 제시된 레드티밍 산출물 양식을 정리한 것이다. 해당 양식은 레드티밍 활동의 계획, 수행, 결과 정리를 지원하기 위한 참고 자료로 활용할 수 있다.

가. 테스트 계획

테스트 계획서는 테스트 계획 수립 및 테스트 관리를 위해 활용하는 문서이다. 초기 테스트 계획 수립 과정에서 결정한 사항을 정리하고, 테스트 진행 중 재계획이 필요한 경우 변경 사항을 반영하여 지속적으로 보완한다.

표 28 테스트 계획서 내용

테스트 계획
테스트 배경
테스트 항목
테스트 범위
테스트 근거
가정 및 제약 조건
이해관계자
테스트 커뮤니케이션
위험 목록:
제품 위험
프로젝트 위험
테스트 전략
시작 및 종료 기준
테스트 완료 기준
독립성 정도
수집할 지표
테스트 데이터 요구 사항
테스트 환경 요구 사항
재테스트
회귀 테스트
중단 및 재개 기준
조직의 테스트 관행과의 차이
테스트 활동 및 예상
인력 배치
역할과 책임
채용 필요성
교육 요구 사항
일정

나. 테스트 완료 보고서

테스트 완료 보고서는 수행된 테스트를 요약하고, 계획과의 차이, 테스트 완료 평가, 잔여 위험, 교훈 등을 정리하기 위한 문서이다.

표 29 테스트 완료 보고서 내용

테스트 완료 보고서
수행된 테스트 요약
계획된 테스트와의 차이점
테스트 완료 평가
진행에 지장을 준 요인
테스트 조치
잔여 위험
테스트 산출물
재사용 가능한 테스트 자산
교훈

다. 테스트 실행 로그

테스트 실행 로그는 하나 이상의 테스트 실행에 대한 세부 정보를 일련의 이벤트로 기록하기 위한 문서이다. 각 이벤트는 목록, 표, 문서 또는 전용 테스트 관리 도구에 저장할 수 있다.

표 30 테스트 실행 로그 내용

테스트 실행 로그
고유 식별자
날짜·시간
설명
영향

참고 문헌

- 국가인공지능전략위원회. (2026, February 25). 보안 취약점 신고·조치·공개 제도(CVD/VDP) 도입 로드맵.
- Anthropic. (2024, June 12). Challenges in red teaming AI systems. <https://www.anthropic.com/news/challenges-in-red-teaming-ai-systems>
- Kumar, A. (2025, July 1). Promptfoo vs. Deepteam vs. PyRIT vs. Garak: The ultimate red teaming showdown for LLMs. DEV Community. <https://dev.to/ayush7614/promptfoo-vs-deepteam-vs-pyrit-vs-garak-the-ultimate-red-teaming-showdown-for-llms-48if>
- Bricken, T., Templeton, A., Batson, J., Chen, B., Jermyn, A., Conerly, T., ... Olah, C. (2023). Towards monosemanticity: Decomposing language models with dictionary learning. Transformer Circuits. <https://transformer-circuits.pub/2023/monosemantic-features/index.html>
- Bullwinkel, B., Minnich, A., Chawla, S., Lopez, G., Pouliot, M., Maxwell, W., de Gruyter, J., Pratt, K., Qi, S., Chikanov, N., Lutz, R., Dheekonda, R. S. R., Jagdagdorj, B.-E., Kim, E., Song, J., Hines, K., Jones, D., Severi, G., Lundeen, R., ... Russinovich, M. (2025). Lessons from red teaming 100 generative AI products. arXiv. <https://arxiv.org/abs/2501.07238>
- Confident AI. (n.d.). DeepEval: The LLM evaluation framework [Computer software]. GitHub. <https://github.com/confident-ai/deepeval/tree/main>
- Confident AI. (n.d.). DeepTeam: The LLM red teaming framework [Computer software]. GitHub. <https://github.com/confident-ai/deepteam>
- Derczynski, L., Galinkin, E., Martin, J., Majumdar, S., & Inie, N. (2024). garak: A framework for security probing large language models. arXiv. <https://arxiv.org/abs/2406.11036>
- Elhage, N., Hume, T., Olsson, C., Schiefer, N., Henighan, T., Kravec, S., Hatfield-Dodds, Z., Lasenby, R., Drain, D., Chen, C., Grosse, R., McCandlish, S., Kaplan, J., Amodei, D., Wattenberg, M., & Olah, C. (2022). Toy models of superposition. arXiv. <https://arxiv.org/abs/2209.10652>
- Fabian, D., & Crisp, J. (2023). Why red teams play a central role in helping organizations secure AI systems. Google. https://services.google.com/fh/files/blogs/google_ai_red_team_digital_final.pdf
- Fabian, D. (2023, July 19). Google's AI red team: The ethical hackers making AI safer. Google Blog. <https://blog.google/technology/safety-security/googles-ai-red-team-the-ethical-hackers-making-ai-safer/>
- International Organization for Standardization. (n.d.). ISO/IEC AWI TS 42119-7: Artificial intelligence — Testing of AI — Part 7: Red teaming [Work item under development]. ISO. <https://www.iso.org/standard/91240.html>

- Japan AI Safety Institute. (2026). Known attacks and their impacts on AI systems (2nd ed.). AISI. https://aisi.go.jp/output/output_security/known_attacks_and_impacts/
- Kumar, R. S. S. (2023, August 7). Microsoft AI red team building future of safer AI. Microsoft Security Blog. <https://www.microsoft.com/en-us/security/blog/2023/08/07/microsoft-ai-red-team-building-future-of-safer-ai/>
- Kumar, V., Liao, Z., Jones, J., & Sun, H. (2024). AmpleGCG-Plus: A strong generative model of adversarial suffixes to jailbreak LLMs with higher success rates in fewer attempts. arXiv. <https://arxiv.org/abs/2410.22143>
- Liao, Z., & Sun, H. (2024). AmpleGCG: Learning a universal and transferable generative model of adversarial suffixes for jailbreaking both open and closed LLMs. arXiv. <https://arxiv.org/abs/2404.07921>
- OpenAI. (2024, November 21). Advancing red teaming with people and AI. <https://openai.com/index/advancing-red-teaming-with-people-and-ai/>
- OpenAI. (2025, April 15). Safety at every step. <https://openai.com/safety/>
- promptfoo. (n.d.). promptfoo: Test your prompts, agents, and RAGs. AI red teaming, pentesting, and vulnerability scanning for LLMs [Computer software]. GitHub. <https://github.com/promptfoo/promptfoo>
- Turner, A. M., Thiergart, L., Leech, G., Udell, D. S., Vazquez, J. J., Mini, U., & MacDiarmid, M. (2023). Steering language models with activation engineering. arXiv. <https://arxiv.org/abs/2308.10248>
- UK Government BEIS. (n.d.). Inspect: A framework for large language model evaluations [Computer software]. GitHub. https://github.com/UKGovernmentBEIS/inspect_ai
- Wang, H., Zhang, R., Wang, J., Li, M., Huang, Y., Wang, D., & Wang, Q. (2025). Joint-GCG: Unified gradient-based poisoning attacks on retrieval-augmented generation systems. arXiv. <https://arxiv.org/abs/2506.06151>
- Wang, K., Variengien, A., Conmy, A., Shlegeris, B., & Steinhardt, J. (2022). Interpretability in the wild: A circuit for indirect object identification in GPT-2 small. International Conference on Learning Representations. <https://openreview.net/forum?id=NpsVSN6o4ul>
- Winniger, T., Addad, B., & Kapusta, K. (2025). Using mechanistic interpretability to craft adversarial attacks against large language models. arXiv. <https://arxiv.org/abs/2503.06269>
- Zou, A., Wang, Z., Carlini, N., Nasr, M., Kolter, J. Z., & Fredrikson, M. (2023). Universal and transferable adversarial attacks on aligned language models. arXiv. <https://arxiv.org/abs/2307.15043>

AI 보안 레드티밍 가이드

발행일 2026년 7월

발행처 과학기술정보통신부 정보보호네트워크정책관 정보보호기획과
한국인터넷진흥원 위협대응단 AI탐지대응팀

참여기관 SK설더스 EQST Lab

감수 전종홍 책임연구원(한국전자통신연구원)

자문 AI 보안 레드팀 실무협의체

※ 본 보고서의 판권은 한국인터넷진흥원이 소유하고 있으며, 당 진흥원의
허가 없이 무단전제 및 복사를 금합니다.



AI 보안 레드티밍 가이드



과학기술정보통신부



한국인터넷진흥원